



SC-300

Microsoft Identity and Access Administrator



LP 2

Implement an
authentication and access
management solution



Agenda



- LP 1 Implement an Identity Management Solution
- LP 2 Implement an Authentication and Access Management Solution
- LP 3 Implement Access Management for Apps
- LP 4 Plan and Implement an Identity Governance Strategy

Outline



- Plan and implement Microsoft Entra multifactor authentication (MFA)
- Manage user authentication
- Plan, implement, and administer Conditional Access
- Manage Microsoft Entra ID Protection
- Implement access management for Azure resources
- Configure and deploy Global Secure Access

Learning objectives

After completing this module, you will be able to:

- 1** Configure and manage authentication including MFA.
- 2** Implement Zero Trust using Conditional Access and other tools.
- 3** Create and manage identities for use with resources and applications.

Secure Microsoft Entra users with multifactor authentication



Objectives

- 1 Configure and deploy self-service password reset
- 2 What is Microsoft Entra multifactor authentication?
- 3 Plan your multifactor authentication
- 4 Configure multifactor authentication methods

Microsoft Entra features to protect cloud assets

- Password complexity rules
- Password expiration rules
- Self-service password reset (SSPR)
- Microsoft Entra Identity Protection
- Microsoft Entra password protection
- Microsoft Entra smart logout
- Microsoft Entra Application Proxy
- Single sign-on (SSO)
- Microsoft Entra Connect
- Microsoft Entra MFA and Conditional Access

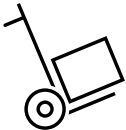
Always think **Zero Trust**

Always verify – Use least privilege access – Assume breach

Configure and deploy self-service password reset



Microsoft Entra self-service password reset

Users can reset their own password	
	No admin/IT intervention
Reduces the loss of user productivity	
	Reduces helpdesk efforts
Users must be enrolled first	
	Requires an assigned license

Enabling SSPR

✖ Diagnose and solve problems

Manage

||| Properties

🛡️ Authentication methods

☰ Registration

🗨️ Notifications

🎨 Customization

🔑 On-premises integration

👤 Administrator Policy

💾 Save ✖ Discard

Self service password reset enabled ⓘ

None

Selected

All

Select group ⓘ

00000000-0000-0000-0000-000000000000

📘

These settings only apply to end users in your organization. Admins are always enabled for self-service password reset and are required to use two authentication methods to reset their password. {0}

© Copyright Microsoft Corporation. All rights reserved.

SSPR Licensing options

Feature	Microsoft Entra ID Free	Microsoft 365 Business Standard	Microsoft 365 Business Premium	Microsoft Entra ID Premium P1 or P2
Cloud-only user password change When a user in Microsoft Entra ID knows their password and wants to change it	•	•	•	•
Cloud-only user password reset When a user in Microsoft Entra ID has forgotten their password		•	•	•
Hybrid user password change or reset with on-premises writeback When a user in Microsoft Entra ID is synchronized from an on-premises directory using Microsoft Entra Connect			•	•

Exercise—Configure and deploy self-service password reset



Microsoft Entra self-service password reset (SSPR) gives users the ability to change or reset their password, with no administrator or helpdesk involvement. If a user's account is locked or they forget their password, they can follow prompts to unblock themselves and get back to work. This ability reduces helpdesk calls and loss of productivity when a user can't sign in to their device or an application.

This exercise teaches the student to enable self-service password reset, register a cell phone number, and test self-service password reset.

[Launch this Exercise in GitHub](#)

Password reset | Properties

Microsoft Entra ID for workforce



Save



Discard

Self service password reset enabled ⓘ

None

Selected

All

Select group ⓘ

Mark 8 Project Team

User—Sign-ins report

Sign-in events

Download

Export Data Settings

Troubleshoot

Refresh

Columns

Date : Last 24 hours

Show dates as : Local

Add filters

User sign-ins (interactive)

User sign-ins (non-interactive)

Service principal sign-ins

Date	Request ID	Application	Status
4/29/2025, 11:00:01 A...	f3a68a2e-4da8-40a5-...	Office365 Shell WCSS...	Success
4/29/2025, 11:00:01 A...	95b5d385-6820-48dc...	Office365 Shell WCSS...	Success
4/29/2025, 11:00:01 A...	997027ac-27cf-4dbb-...	Office365 Shell WCSS...	Success
4/29/2025, 10:59:56 A...	0d09122f-d2a7-4a59...	Microsoft Office 365 ...	Success
4/29/2025, 10:59:47 A...	22683795-a4d0-4356...	Azure Portal	Success
4/29/2025, 10:35:47 A...	d4c2b8a2-c133-4b32...	Azure Portal	Success
4/29/2025, 10:35:43 A...	ab0f2fd3-f7e7-4416-...	Azure Portal	Interrupted
4/28/2025, 3:45:14 PM	8f6b79c9-8867-4506-...	Azure Portal	Success
4/28/2025, 3:42:21 PM	70272ee6-de2c-4f1e-...	Azure Portal	Success
4/28/2025, 3:42:16 PM	08686a71-add5-4b6a...	Azure Portal	Interrupted

Activity Details: Sign-ins

Basic info

Location

Device info

Authentication Details

Conditional Access

Report-only

Date

4/29/2025, 10:35:43 AM

Request ID

ab0f2fc

Correlation ID

fd7cca1

Authentication requirement

Multifactor authentication

Agent Type

Not Agentic

Status

Interrupted

Continuous access evaluation

No

Additional Details

This is an expected part of the login flow, where a user is asked if they want to remain signed into this browser to make further logins easier. For more details, see <https://techcommunity.microsoft.com/t5/microsoft-entra/the-new-azure-ad-sign-in-and-keep-me-signed-in-experiences/td-p/128267>

Troubleshoot Event

Follow these steps:

1. Review the diagnosis and act on suggested fixes.

User

Adele Vance

Username

adelev@contoso.com

The **Authentication Details** or **Conditional Access** tab of the event details shows you the status code or which policy triggered the MFA prompt.

What is Microsoft Entra multifactor authentication?



Value and capabilities of Microsoft Entra MFA

Value

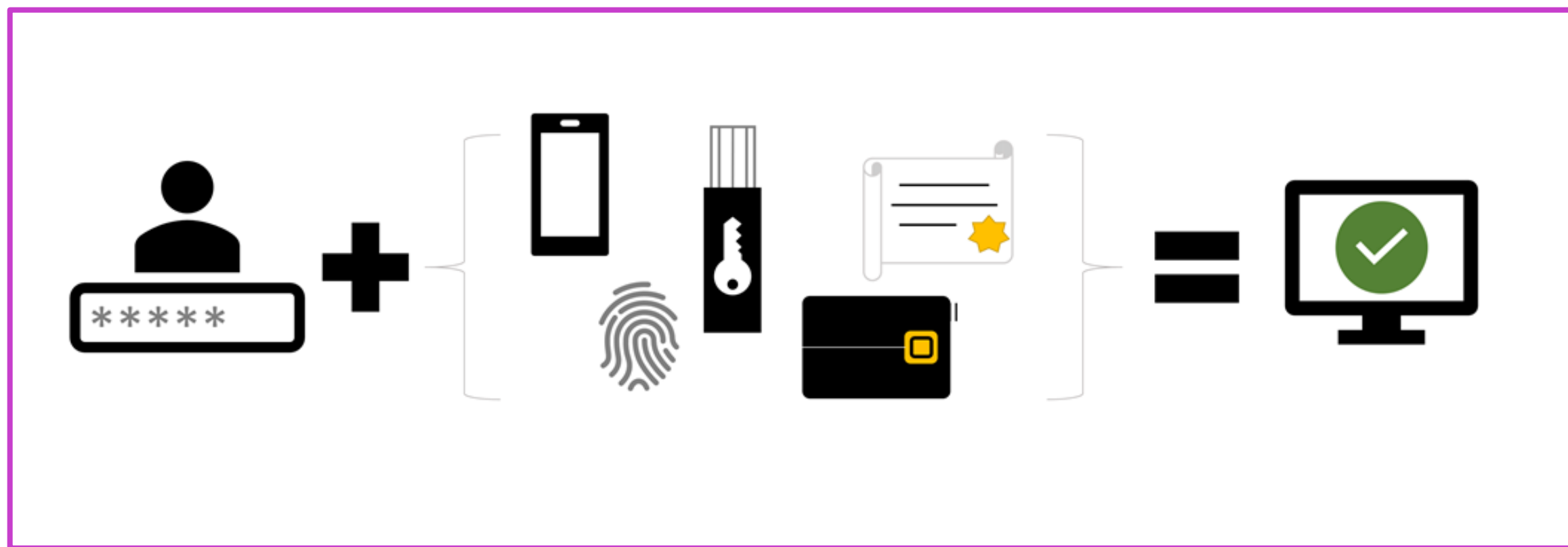
- More secure than passwords
- Quick and easy to set up and manage
- Strong identity verification
- Stronger security
- Often supports compliance goals
- Many different types of authentication methods, with different levels of security

Categories of authentication factors

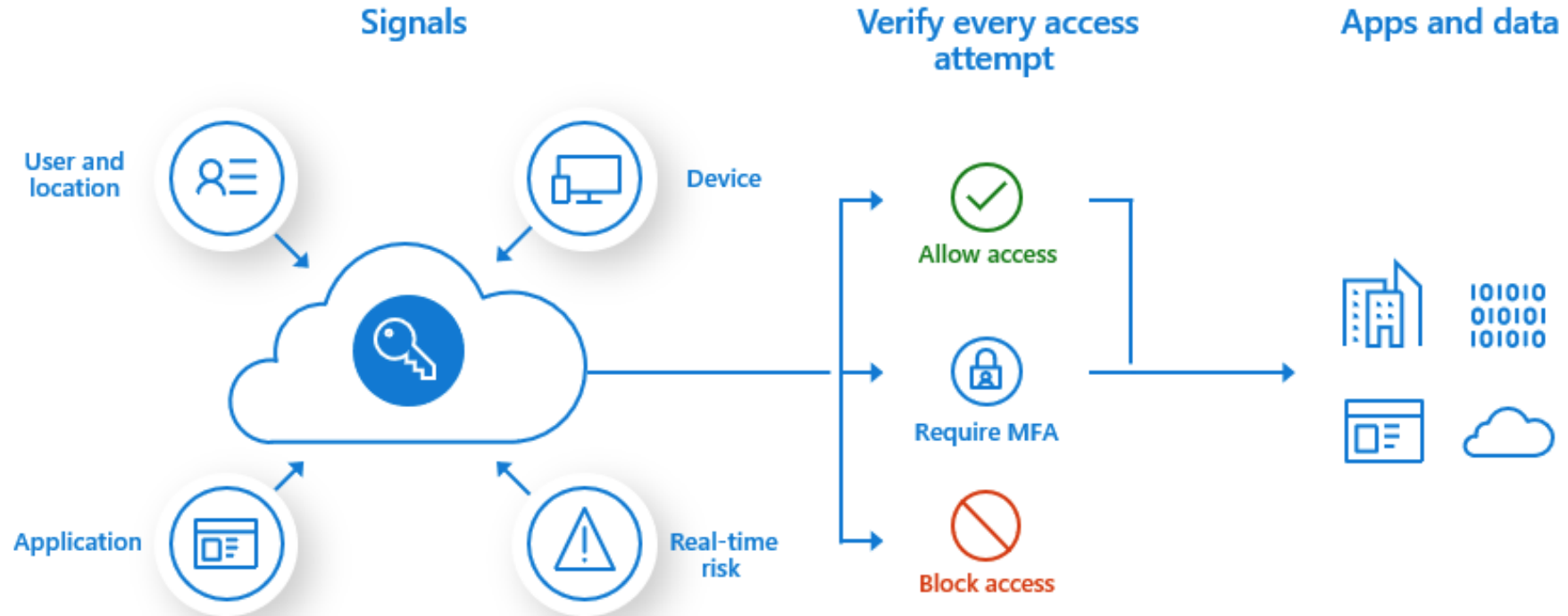
Something you know

Something you possess

Something you are



Enabling MFA with Conditional Access



Set up a Conditional Access policy that requires a user/group to have MFA required for access to specific resources.

User states of MFA



Disabled—default state, user not enrolled in MFA.



Enabled—user is enrolled in MFA, but can still use their password. At each login they are prompted to register for an MFA authentication method.



Enforced—user is enrolled in MFA, and has either completed their MFA registration; or will be forced to complete it on their next login.

Considerations for Microsoft Entra MFA based on the infrastructure



Cloud Only setup—nothing additional required to set up Microsoft Entra MFA



Hybrid Identity—Microsoft Entra Connect must be deployed and synchronized/federated with your on-premises Active Directory Domain Services



Need on-premises legacy apps—Microsoft Entra Application Proxy must be deployed



Use Microsoft Entra MFA with a RADIUS Authentication—a Network Policy Server (NPS) must be set up and configured

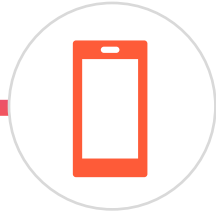
Plan your multifactor authentication deployment



Deployment considerations

- Get employee buy-in
 - User communications (posters, emails, and other support items)
- Consider rolling MFA out in waves
- Create a full communications plan
- Tie your MFA roll-out with Conditional Access compliance
 - Specific devices, working location, application or data access
- Select your authentication methods
- Plan MFA registration process
- Add on-premises systems after MFA is established

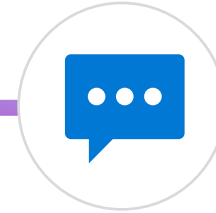
Supported authentication methods



Mobile app verification



Call to a phone



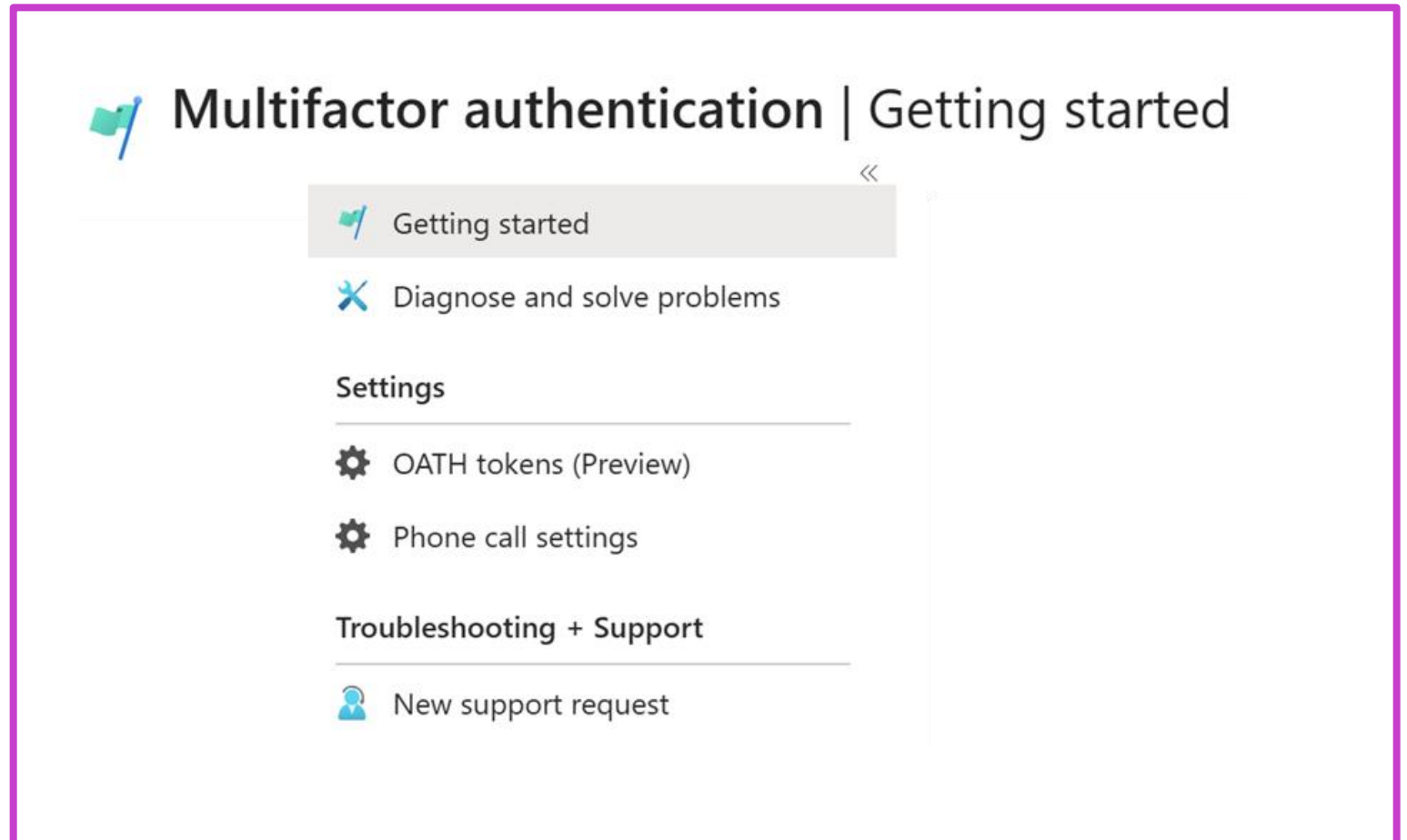
Text message to a phone

Exercise—enable Microsoft Entra multifactor authentication



This exercise teaches students how to configure multifactor authentication policies, set up Conditional Access rules, and configure Microsoft Entra MFA for passwords.

[Launch this Exercise in GitHub](#)



Configure multifactor authentication methods



Azure authentication methods

AuthN methods when deploying MFA

- Microsoft Authenticator app
- Windows Hello for Business
- FIDO2 security key
- OATH hardware token (preview)
- OATH software token
- SMS
- Voice call

Supplemental AuthN for niche use

- Security questions
 - Non-admins only
- Email address
 - Part of SSPR if enabled
- App passwords
 - For legacy apps that don't directly support Azure MFA

Registering an authentication method



lidiah

Let's keep your account secure

We'll help you set up another way to verify it's you.

[Use a different account](#)

[Learn more about verifying your identity](#)

[Next](#)

Microsoft Authenticator



Start by getting the app

On your phone, install the Microsoft Authenticator app. [Download now](#)

After you install the Microsoft Authenticator app on your device, choose "Next".

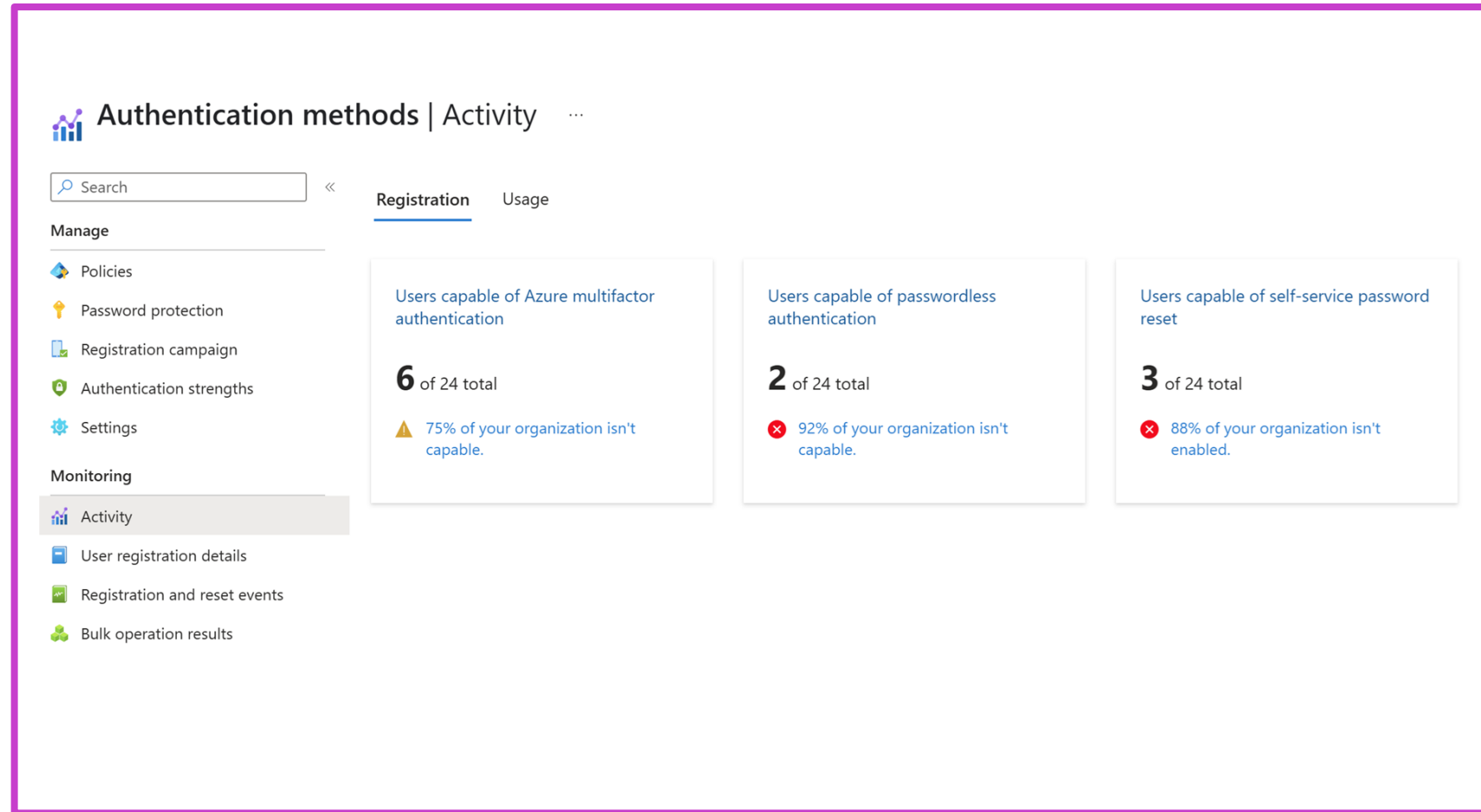
[I want to use a different authenticator app](#)

[Next](#)

[I want to set up a different method](#)

Monitoring adoption

- Microsoft Entra ID includes a **Usage & insights** view in the **Monitoring** section where you can monitor the authentication methods activity. From here you can view the adoption of MFA.
- In addition to the overall registration numbers, you can also see the success and failure of registrations per authentication method.
- You can also learn more about MFA usage in your organization through the **Usage** tab on the main view.



Extend MFA to devices



Require MFA for devices

Use Conditional Access rules to extend MFA to devices and device enrollment.

Two methods:

- 1) Policy for Microsoft Intune or Microsoft Intune Enrollment (seen in picture).
- 2) Policy within Intune device settings.

Home > Contoso > Security > Conditional Access >

New

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *
MFA for Devices ✓

Assignments

Users or workload identities ⓘ
[Specific users included](#)

Cloud apps or actions ⓘ
1 app included

Conditions ⓘ
0 conditions selected

Access controls

Grant ⓘ
1 control selected

Session ⓘ
0 controls selected

Enable policy
Report-only On Off

Create

Control access based on all or specific cloud apps or actions. [Learn more](#)

Select what this policy applies to
Cloud apps

Include Exclude

☐ None
☐ All cloud apps
☒ Select apps

Select
[Microsoft Intune Enrollment](#)

MI Microsoft Intune Enrollment d4ebce55-015a-49b5-a083-c84d1797ae8c

Grant

Control access enforcement to block or grant access. [Learn more](#)

☐ Block access
☒ Grant access

☒ Require multifactor authentication ⓘ
☐ Require device to be marked as compliant ⓘ
☐ Require Hybrid Azure AD joined device ⓘ
☐ Require approved client app ⓘ
[See list of approved client apps](#)
☐ Require app protection policy ⓘ
[See list of policy protected client apps](#)
☐ Require password change ⓘ

For multiple controls
☒ Require all the selected controls
☐ Require one of the selected controls

Protecting Microsoft Entra ID from device attacks

Monitor the device:

- Device registration and Microsoft Entra ID join
- Noncompliant devices accessing applications
- BitLocker key retrieval
- Device administrator roles
- Sign-ins to virtual machines

Logs with device data:

- Microsoft Entra ID audit logs
- Sign-in logs
- Microsoft 365 audit logs
- Azure Key Vault logs

Tools to use:

- Microsoft Sentinel
- Azure Monitor
- Azure Event Hubs

Monitor MFA



Monitor Microsoft Entra ID MFA activity

Use the Microsoft Entra sign-in report to review MFA usage.

Data available in the report:

- Was the sign-in challenged with MFA?
- How did the user complete MFA?
- Which authentication methods were used during a sign-in?
- Why was the user unable to complete MFA?
- How many users are challenged for MFA?
- How many users are unable to complete the MFA challenge?
- What are the common MFA issues end users are running into?

References

Planning a cloud-based Microsoft Entra multifactor authentication deployment

<https://learn.microsoft.com/azure/active-directory/authentication/howto-mfa-getstarted>

Deploy Microsoft Entra self-service password reset

<https://learn.microsoft.com/azure/active-directory/authentication/howto-sspr-deployment>



Manage user authentication



Objectives

- 1 Administer authentication methods (FIDO2/Passwordless)
- 2 Implement an authentication solution based on Windows Hello for Business
- 3 Disable accounts and revoke sessions
- 4 Deploy and manage password protection
- 5 Configure smart lockout thresholds
- 6 Kerberos in Microsoft Entra ID
- 7 Certificate-based authentication
- 8 Microsoft Entra ID user authentication in Virtual Machines (VMs)

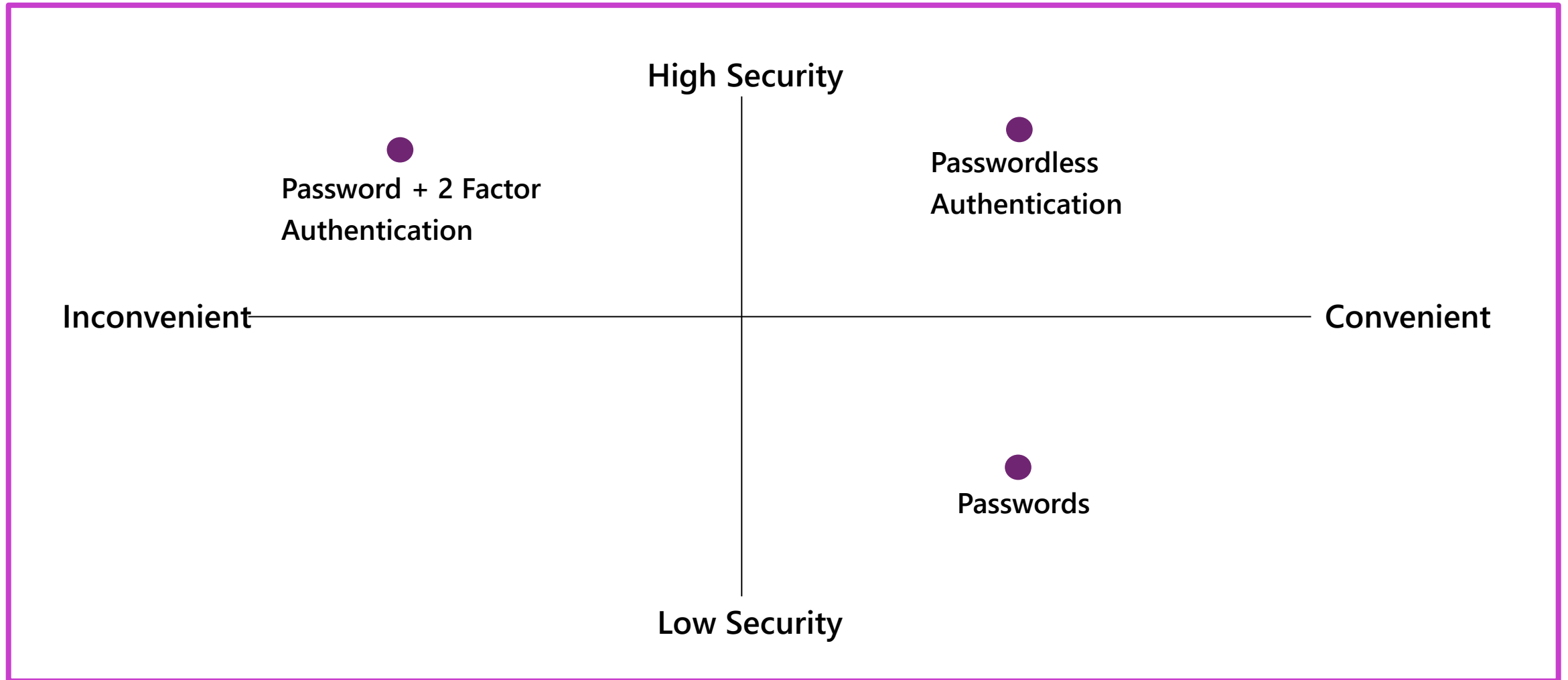
Administer authentication methods



Authentication methods

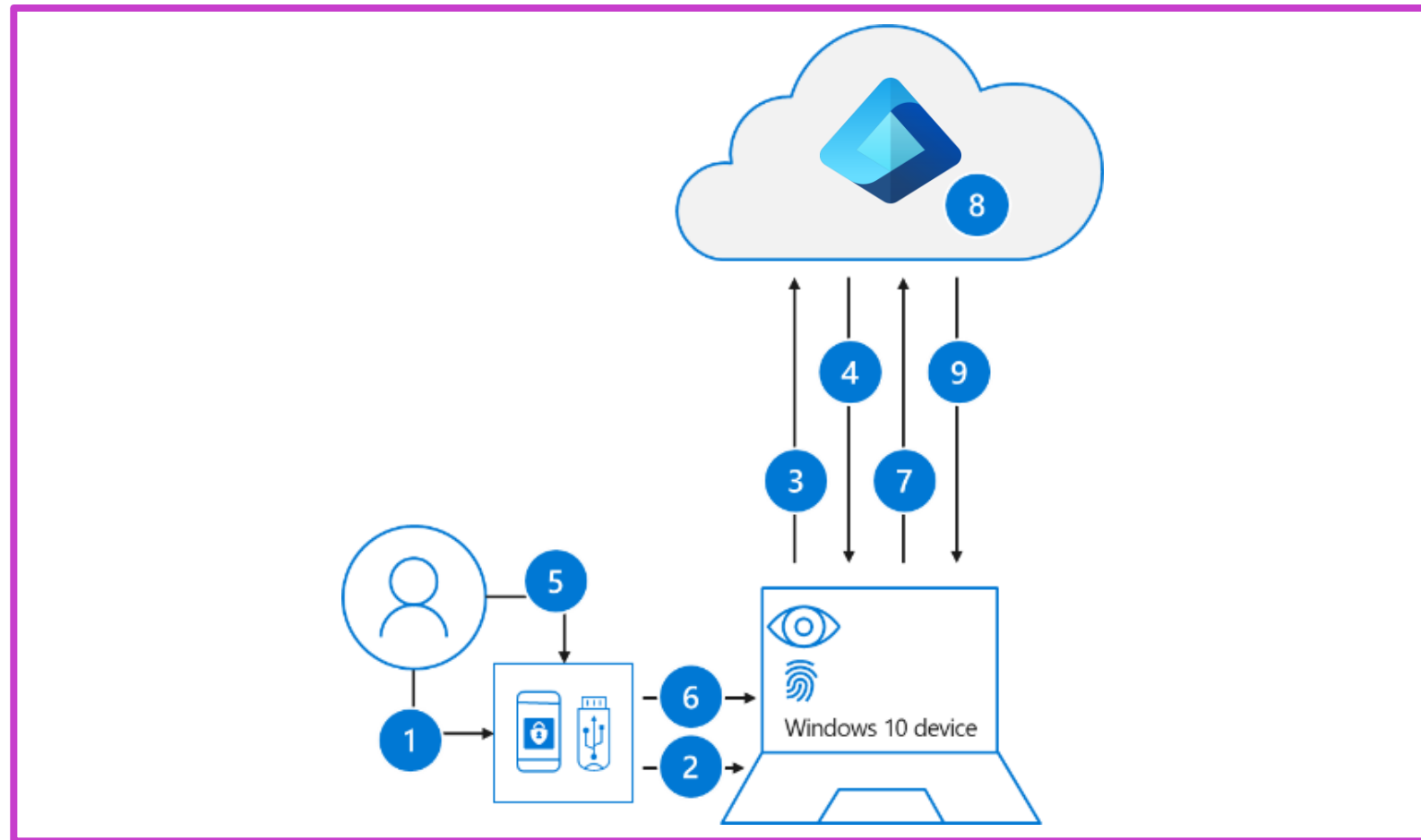
Bad: Password	Good: Password and...	Better: Password and...	Best: Passwordless
123456	 SMS	 Authenticator (Push Notifications)	 Authenticator (Phone Sign-in)
qwerty			 Window Hello
password	 Voice	 Software Tokens OTP	 FIDO2 security key
iloveyou			 Certificates
Password1		 Hardware Tokens OTP (Preview)	

Authentication method strength and security



What is FIDO2?

- FIDO2 security keys are an unphishable specification-based passwordless authentication method that can come in any form factor.
- Fast Identity Online (FIDO) is an open specification for passwordless authentication.
- FIDO allows users and organizations to leverage the specification to sign in to their resources without a username or password using an external security key or a platform key built into a device.



Implement FIDO2 security keys

- **Allow self-service setup**—if set to NO, users cannot register a FIDO key.
- **Enforce attestation**—if set to YES, the FIDO key has to be published and verified with FIDO-Alliance.
- **Enforce key restrictions**—only set to YES if your organization wants to specify valid keys via AAGuids.

Passkey (FIDO2) settings

Enable and Target

Configure

GENERAL

Allow self-service set up

YesNo

Enforce attestation

YesNo

KEY RESTRICTION POLICY

Enforce key restrictions

YesNo

Restrict specific keys

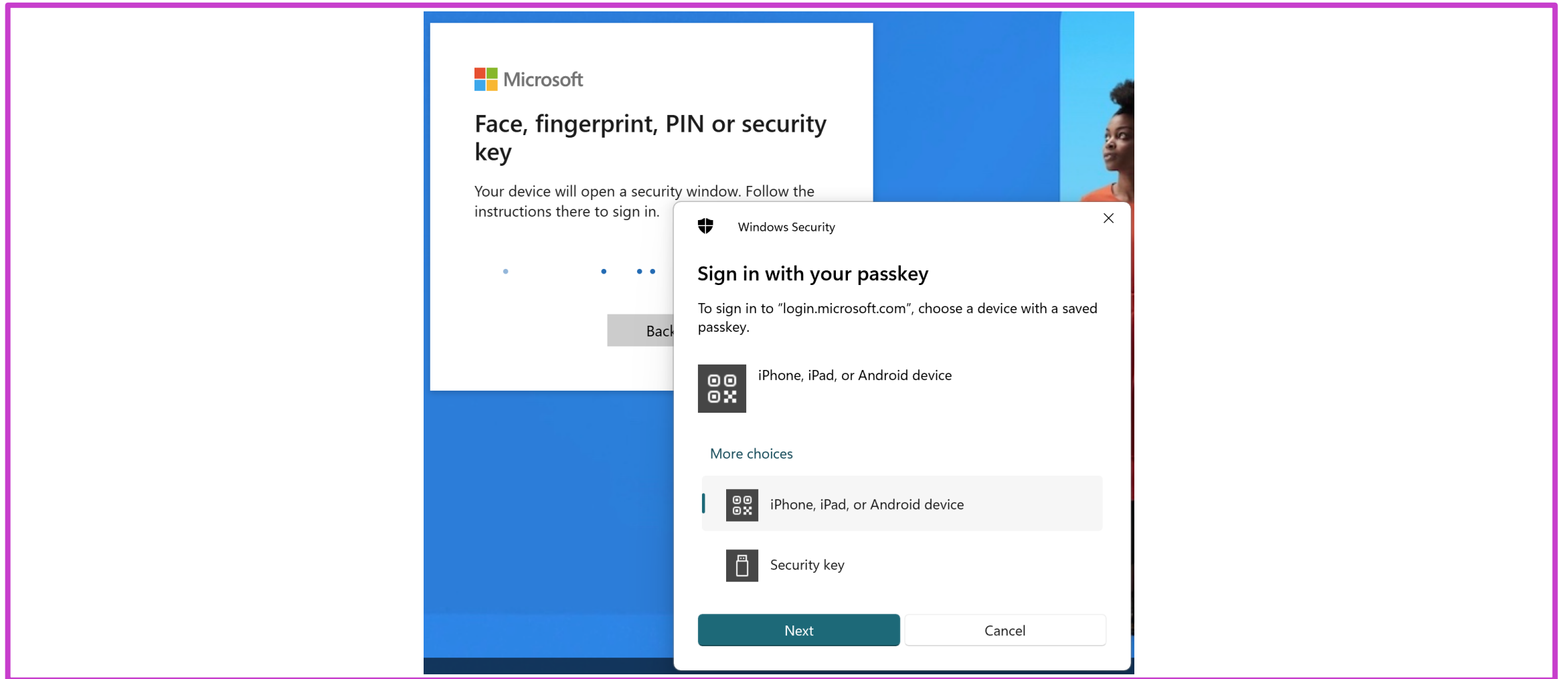
AllowBlock

☐ Microsoft Authenticator ⓘ

Add AAGUID

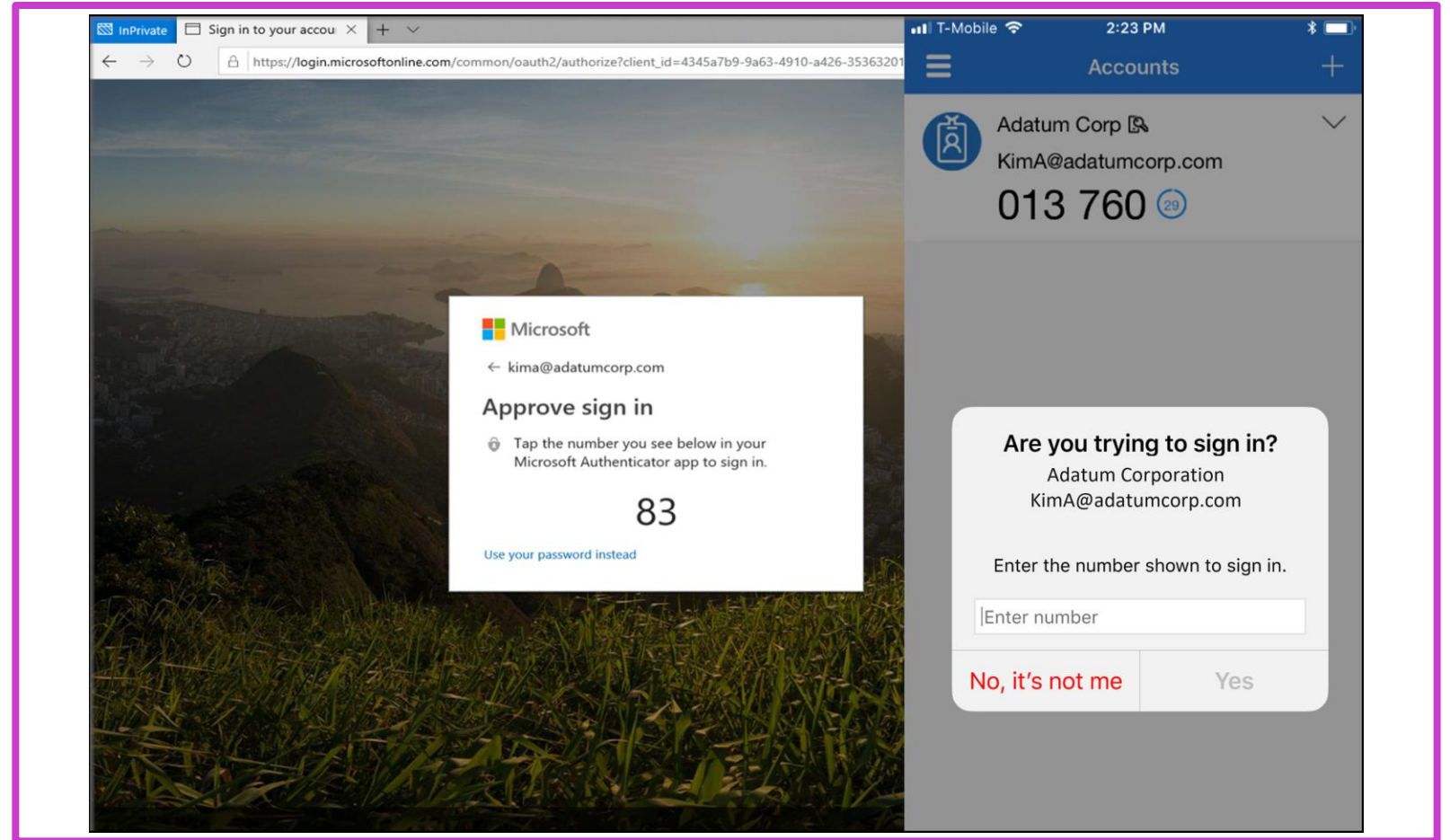
No AAGuids have been added.

Signing in with passwordless credential



Microsoft Authenticator

- Approve through mobile app – Use a pin and or verify a number
- Generate an OATH verification code – One-time code entered into sign-in UI
- Enforce with policy and governance



OATH tokens



Multifactor authentication | OATH tokens (Preview) ...

Getting started

Diagnose and solve problems

Settings



OATH tokens (Preview)



Phone call settings

Troubleshooting + Support



New support request

<<



Upload



Download



Delete



Refresh



Documentation



Columns



Got feedback?

To get started, select the Upload button above and choose a .csv file. This file should contain the secret keys for the OATH token: manufacturer, model".

[For more information on available authentication and verification methods, view the public documentation.](#)

Username

Enter a user name

Show

All

Name	Username	Serial Number	Model
No results			

OATH—Open Authentication

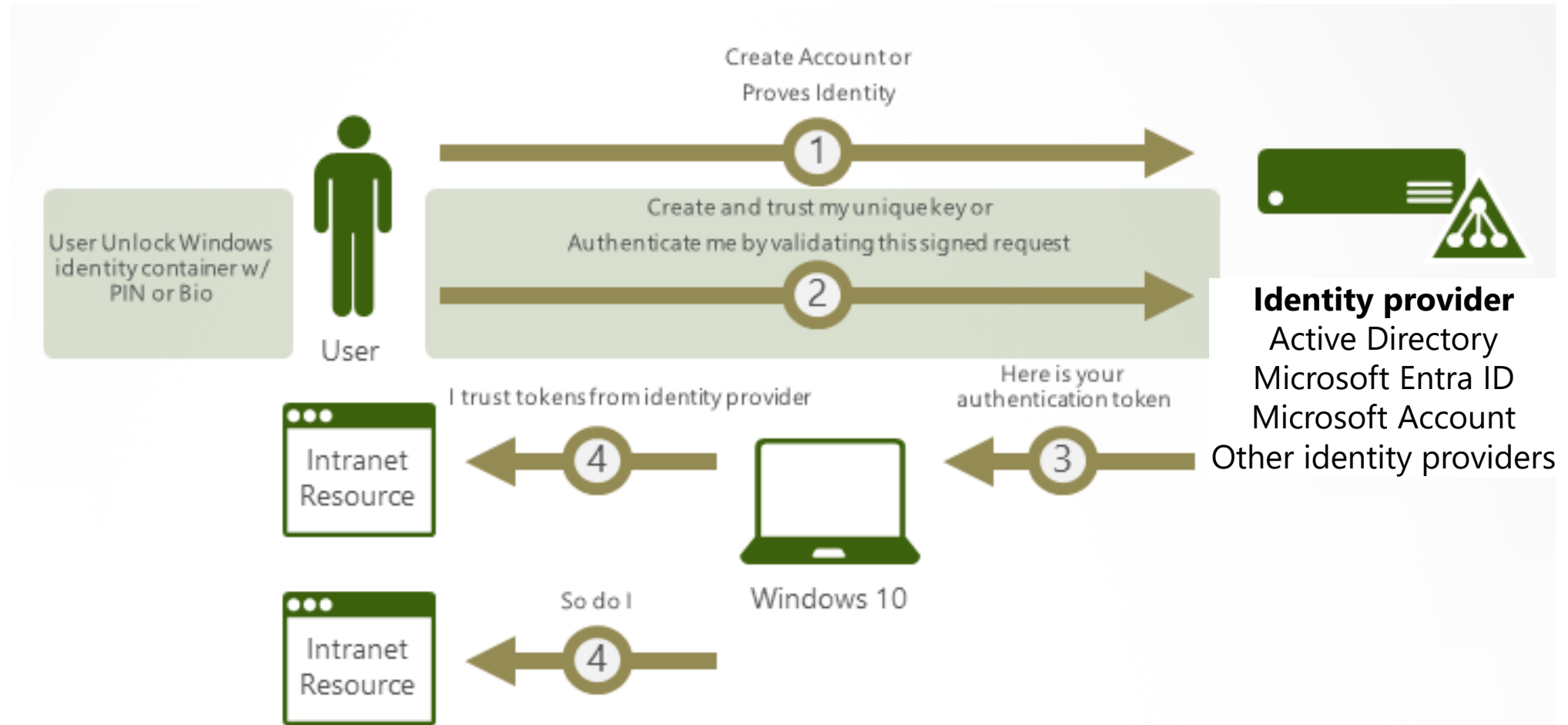
TOTP—Time-based One Time Password

Software or hardware implementations available in Microsoft Entra ID

Implement an authentication solution based on Windows Hello for Business



Authentication in Windows Hello



Windows Hello for Business—key points

Key points

Credentials are based on certificate or asymmetrical key pair.

Credentials can be bound to the device, and the token that is obtained using the credential is also bound to the device.

Identity providers (such as Microsoft Entra ID, or a Microsoft account) validate user identity and maps the Windows Hello public key to a user account.

Keys can be generated in hardware (TPM 1.2 or 2.0 for enterprises, and TPM 2.0 for consumers) or software.

Two-factor authentication with the combination of a key or certificate tied to a device and something that the person knows (a PIN) or something that the person is (biometrics).

The private key never leaves a device when using TPM.

Personal (Microsoft account) and corporate (Active Directory or Microsoft Entra ID) accounts use a single container for keys.

Disable accounts and revoke user sessions



Describe how to disable accounts and revoke user sessions

There are occasions when you need to disable an account and/or revoke an existing user session.

- **Access tokens and refresh token**
 - When a user authenticates, they are issued an access token (Valid for one hour) and Refresh tokens.

Primary steps that you need to take:

- 1) Disable the account.
- 2) Reset the password.
- 3) Disable any devices, tokens, or other references.

Disable accounts: On-premises and Microsoft Entra users

Disabling and revoking access (PowerShell)

- On-premises user

- Disable account → `Disable-ADAccount -Identity johndoe`
- Reset password → `Set-ADAccountPassword -Identity johndoe -Reset -NewPassword (ConvertTo-SecureString -AsPlainText "p@ssw0rd1" -Force)`
- Recommended to run password reset twice to avoid pass-the-hash style attacks

- Microsoft Entra user

- Disable account → `Set-AzureADUser -ObjectId johndoe@contoso.com -AccountEnabled $false`
- Revoke refresh token → `Revoke-AzureADUserAllRefreshToken -ObjectId johndoe@contoso.com`
- Disable user devices → `Get-AzureADUserRegisteredDevice -ObjectId johndoe@contoso.com | Set-AzureADDevice -AccountEnabled $false`

Deploy and manage password protection



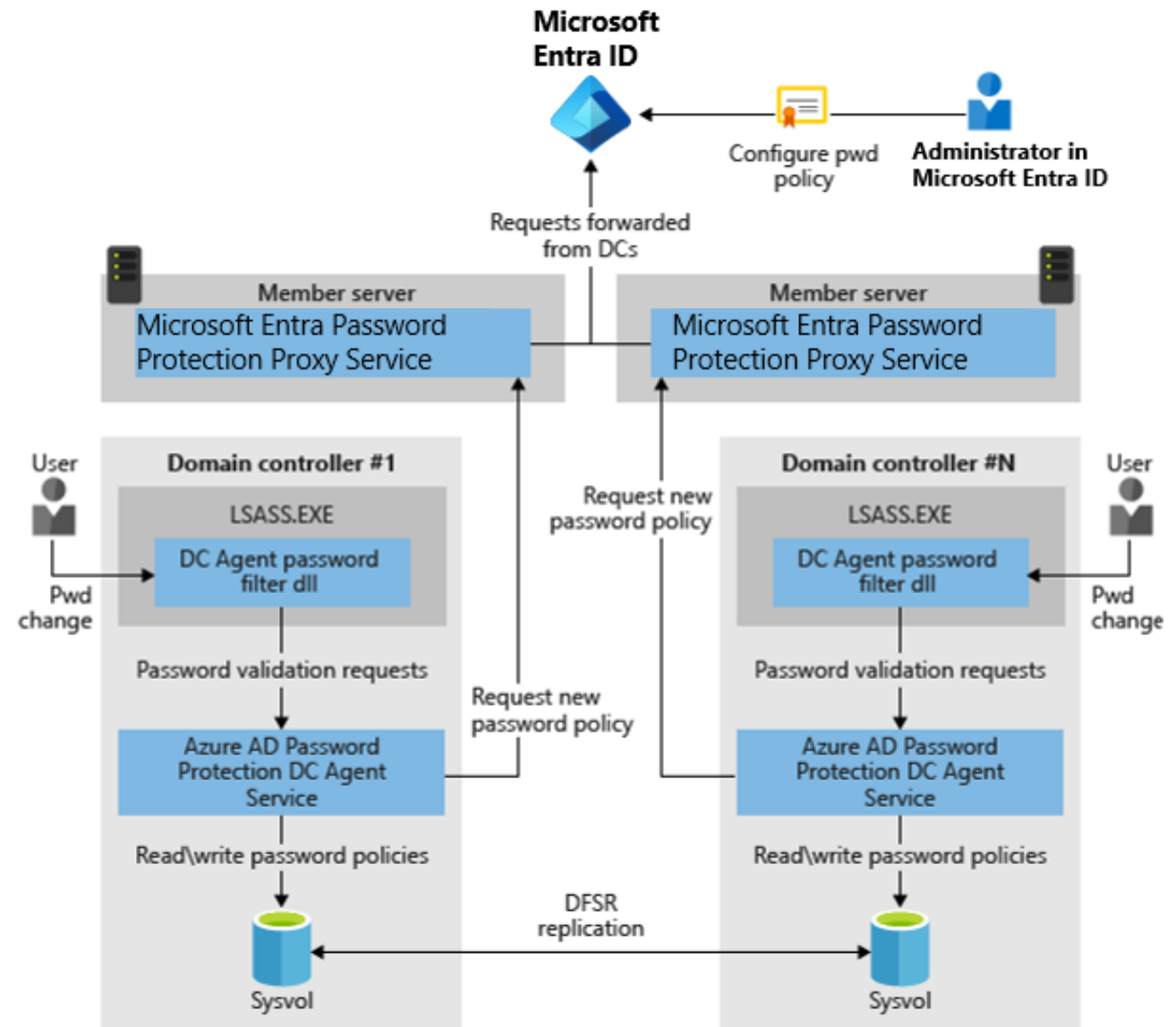
Microsoft Entra password protection

Users often create easy to guess passwords that are weak against dictionary-based attacks. To help you enforce strong passwords, Microsoft Entra password protection provides a global and custom banned password list. Benefits include:

- Domain controllers (DCs) never have to communicate directly with the internet.
- No new network ports.
- No AD DS schema changes required.
- No minimum AD DS domain or forest functional level (DFL/FFL) required.
- The software doesn't create or require accounts in the AD DS domains that it protects.
- User clear-text passwords never leave the DC.
- The software isn't dependent on other Microsoft Entra features.
- Incremental deployment is supported.

Deployment technology

How the basic components of Microsoft Entra password protection are configured and work together



Deployment approach

Strategy for rolling out password protection—don't just turn it on

Audit mode

Audit mode is the default initial setting, where passwords can continue to be set. Passwords that would be blocked are recorded in the event log. After you deploy the proxy servers and DC agents in audit mode, monitor the impact that the password policy will have on users when the policy is enforced.

Common findings

During the audit stage, many organizations find:

- They need to improve existing operational processes to use more secure passwords.
- Users often use unsecure passwords.
- Organizations need to inform users about the upcoming change in security enforcement, the possible impact on them, and how to choose more secure passwords.

Considerations

- Multiple forest considerations
- Read-only domain controller considerations
- High availability considerations

Configure smart lockout thresholds



How smart lockout works

- By default, smart lockout locks the account for one minute after 10 failed attempts
- The account is locked again after subsequent attempts, for increasing periods
- Smart lockout is always on for all Microsoft Entra ID customers
- The default configuration can be customized
- Smart lockout doesn't guarantee that a genuine user is never locked out, but it is tailored to resisting bad actors
- Smart lockout can be integrated with hybrid deployments

Exercise—manage Microsoft Entra smart lockout values



This exercise teaches students to customize the Microsoft Entra smart lockout values.

[Launch this Exercise in GitHub](#)

Home > Authentication methods

Authentication methods | Password protection

Microsoft Entra ID Security

Search

Save Discard | Got feedback?

Manage

Policies

Password protection

Registration campaign

Authentication strengths

Settings

Custom smart lockout

Lockout threshold ⓘ

10

Lockout duration in seconds ⓘ

60

Custom banned passwords

Enforce custom list ⓘ

Yes No

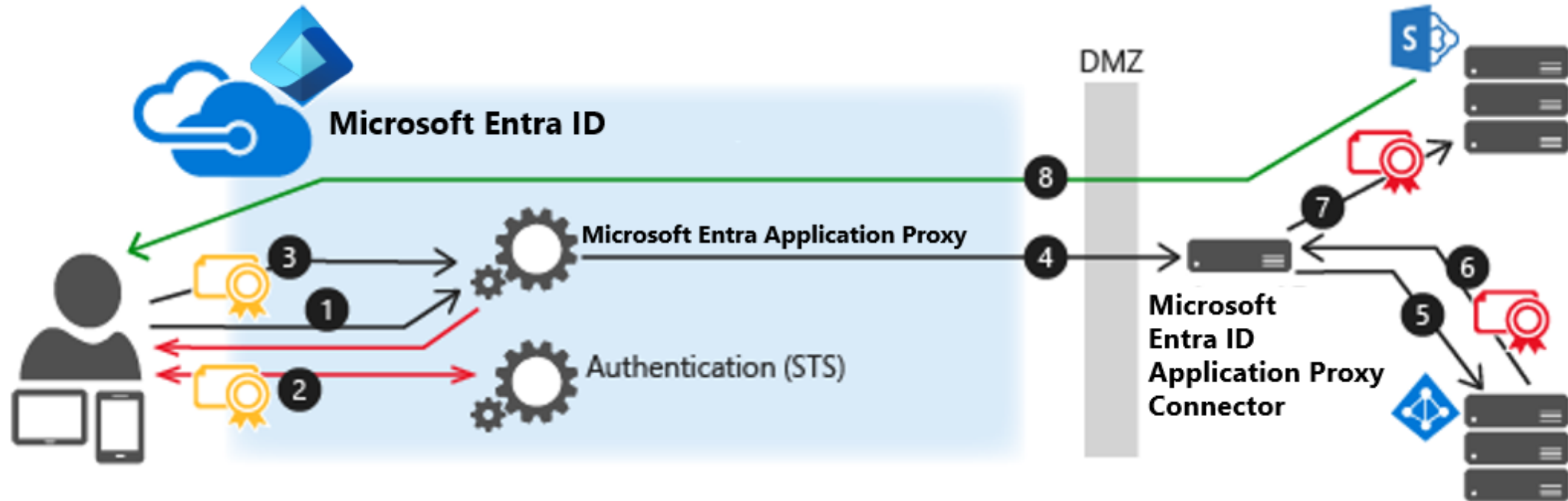
Custom banned password list ⓘ

© Copyright Microsoft Corporation. All rights reserved.

Kerberos in Microsoft Entra ID



Configure Kerberos for use in Microsoft Entra ID



Environment setup needed:

- Integrated Windows Authentication enabled on web apps
- All apps must have a service principal
- Server running the Kerberos connector must be in domain joined

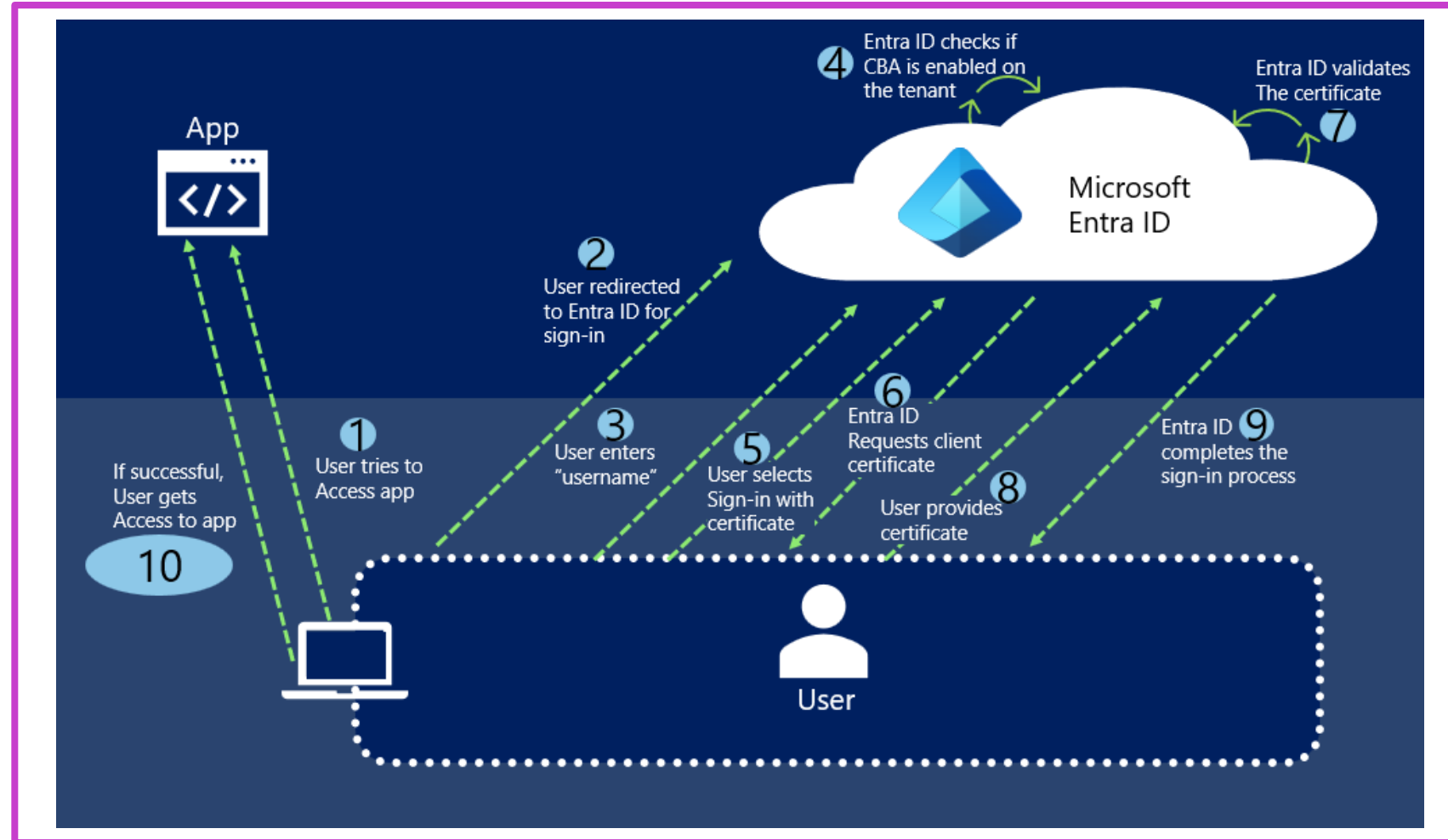
Certificate-based authentication



Implement certificate-based authentication in Microsoft Entra ID

The following scenarios are supported:

- User sign-ins to web browser-based applications on all platforms.
- User sign-ins on mobile native browsers.
- Support for granular authentication rules for multifactor authentication by using the certificate issuer **Subject** and **policy OIDs**.
- Configuring certificate-to-user account bindings by using the certificate Subject Alternate Name (SAN) principal name and SAN RFC822 name.



Enable certificate-based authentication

Certificate-based authentication settings

Certificate-based authentication is a passwordless, phishing-resistant authentication method

Enable and Target

Configure

Enable

Include

Exclude

Target

All users

Select groups

Name

All users

Certificate-based authentication settings

Certificate-based authentication is a passwordless, phishing-resistant authentication method th

Enable and Target

Configure

Certificate revocation list (CRL) validation

This setting requires a CRL check for every certificate authority (CA). If the CRL distribution p

Require CRL validation (recommended)

Issuer Hints

Enable issuer hints to show only the valid certificates in the certificate picker during authenti

Issuer Hints

Authentication binding

The authentication binding policy helps determine the strength of your certificate-based aut

Protection Level

Single-factor authentication

Multi-factor authentication

Required Affinity Binding

Low

High

+ Add rule

Certificate issuer

Policy OID

© Copyright Microsoft Corporation. All rights reserved.

Microsoft Entra ID user authentication for VMs



Benefits of Microsoft Entra ID user authentication in VMs

Benefits:

- Use Microsoft Entra credentials to sign in to Windows VMs in Azure.
- Reduce reliance on local administrator accounts.
- Password complexity and password lifetime policies configured for your Microsoft Entra ID.
- Configure Conditional Access policies to require multifactor authentication and other signals such as risky user or sign-in risk.

Supported operation systems:

- Windows Server 2019 Datacenter edition and later.
- Windows 10 1809 and later.
- Windows 11.
- Linux virtual machine.

Configure Windows VMs

Identity

Enable system assigned managed identity ⓘ



System managed identity must be on to login with Microsoft Entra ID credentials. [Learn more](#)

Microsoft Entra ID

Login with Microsoft Entra ID ⓘ



RBAC role assignment of Virtual Machine Administrator Login or Virtual Machine User Login is required when using Microsoft Entra ID login. [Learn more](#)

To use Microsoft Entra sign-in for Windows VM in Azure, you must:

- First enable the Microsoft Entra sign-in option for your Windows VM.
- Then configure Azure role assignments for users who are authorized to sign into the VM.

Configure Microsoft Entra ID sign-in for Linux VMs

You can enable Microsoft Entra ID sign-in for any of the supported Linux distributions mentioned using the Azure portal. As an example, to create an Ubuntu Server 22.04 Long Term Support (LTS) VM in Azure with Microsoft Entra ID authentication:

1. Sign into the Azure portal, with an account that has access to create VMs, and select **+ Create** a resource.
2. Select **Create** under Ubuntu Server 18.04 LTS in the Popular view.
3. On the **Management** tab, Check the box to enable **Login with Microsoft Entra ID**.
4. Ensure **System assigned managed identity** is checked.
5. Complete the Linux virtual machine setup.

References (1 of 2)

Enable combined security information registration in Microsoft Entra ID

<https://learn.microsoft.com/azure/active-directory/authentication/howto-registration-mfa-sspr-combined>

Create a resilient access control management strategy with Microsoft Entra ID

<https://learn.microsoft.com/azure/active-directory/authentication/concept-resilient-controls>

Microsoft Entra authentication methods API overview

<https://learn.microsoft.com/graph/api/resources/authenticationmethods-overview>

Windows Hello for Business overview

<https://learn.microsoft.com/windows/security/identity-protection/hello-for-business/hello-overview>

Authentication methods in Microsoft Entra ID—Microsoft Authenticator app

<https://learn.microsoft.com/azure/active-directory/authentication/concept-authentication-authenticator-app>

Passwordless authentication options for Microsoft Entra ID

<https://learn.microsoft.com/azure/active-directory/authentication/concept-authentication-passwordless>



References (2 of 2)

Authentication methods in Microsoft Entra ID—OATH tokens

<https://learn.microsoft.com/azure/active-directory/authentication/concept-authentication-oath-tokens>

Configure and enable users for SMS-based authentication using Microsoft Entra ID

<https://learn.microsoft.com/azure/active-directory/authentication/howto-authentication-sms-signin>

Authentication methods in Microsoft Entra ID—phone options

<https://learn.microsoft.com/azure/active-directory/authentication/concept-authentication-phone-options>

Enforce on-premises Microsoft Entra password protection for Active Directory Domain Services

<https://learn.microsoft.com/azure/active-directory/authentication/concept-password-ban-bad-on-premises>

Enable on-premises Microsoft Entra password protection

<https://learn.microsoft.com/azure/active-directory/authentication/howto-password-ban-bad-on-premises-operations>

Step-by-step: Implementing Microsoft Entra password protection on-premises

<https://techcommunity.microsoft.com/t5/itops-talk-blog/step-by-step-implementing-azure-ad-password-protection-on/ba-p/563342>



Plan, implement, and administer Conditional Access



Objectives

- 1 Plan and implement security defaults
- 2 Plan Conditional Access policies
- 3 Implement conditional access policy controls and assignments (targeting, applications, and conditions)
- 4 Template-based conditional access
- 5 Test and troubleshoot conditional access policies
- 6 Implement application controls and session management
- 7 Continuous Access Evaluation
- 8 Authentication context

Explore security defaults



Security defaults

The screenshot displays the Microsoft Entra ID management console. On the left, the navigation pane shows the 'Identity' section expanded, with 'Overview' selected. The main content area is titled 'Properties' and contains several configuration options: 'Data location' (United States datacenters), 'Notification language' (English), 'Tenant ID', 'Technical contact', 'Global privacy contact', and 'Privacy statement URL'. Below these is the 'Access management for Azure resources' section, which includes a 'Security defaults' subsection. This subsection contains a message stating that security defaults are basic identity security mechanisms recommended by Microsoft, and that they will be automatically enforced. It also includes a note indicating that the organization is currently using Conditional Access policies, which prevents enabling security defaults, and suggests using Conditional Access to configure custom policies that enable the same behavior provided by security defaults.

Home
What's new
Diagnose & solve problems

Favorites

Identity

Overview

Users

Groups

Devices

Applications

Roles & admins

Billing

Settings

Protection

Identity governance

External Identities

+ Add Manage tenants What's new Preview features Got feedback?

Overview Monitoring **Properties** Recommendations Tutorials

Data location United States datacenters

Notification language English

Tenant ID

Technical contact

Global privacy contact

Privacy statement URL

Access management for Azure resources

Security defaults

Security defaults are basic identity security mechanisms recommended by Microsoft. When enabled, these recommendations will be automatically enforced in your organization. Administrators and users will be better protected from common identity-related attacks.

i Your organization is currently using Conditional Access policies which prevents you from enabling security defaults.
You can use Conditional Access to configure custom policies that enable the same behavior provided by security defaults.

Who's it for?

Who should use security defaults?

- Organizations that want to increase their security posture but don't know how or where to start
- Organizations utilizing the free tier of Microsoft Entra ID

Who shouldn't use security defaults?

- Organizations currently using Conditional Access policies to bring signals together, make decisions, and enforce organizational policies
- Organizations with Microsoft Entra ID Premium licenses
- Organizations with complex security requirements that warrant using Conditional Access

Exercise—work with security defaults



This exercise teaches the student how to enable security defaults in Microsoft Entra ID.

[Launch this Exercise in GitHub](#)

Enable Security defaults

Security defaults is a set of basic identity security mechanisms recommended by Microsoft. When enabled, these recommendations will be automatically enforced in your organization. Administrators and users will be better protected from common identity related attacks.

[Learn more](#)

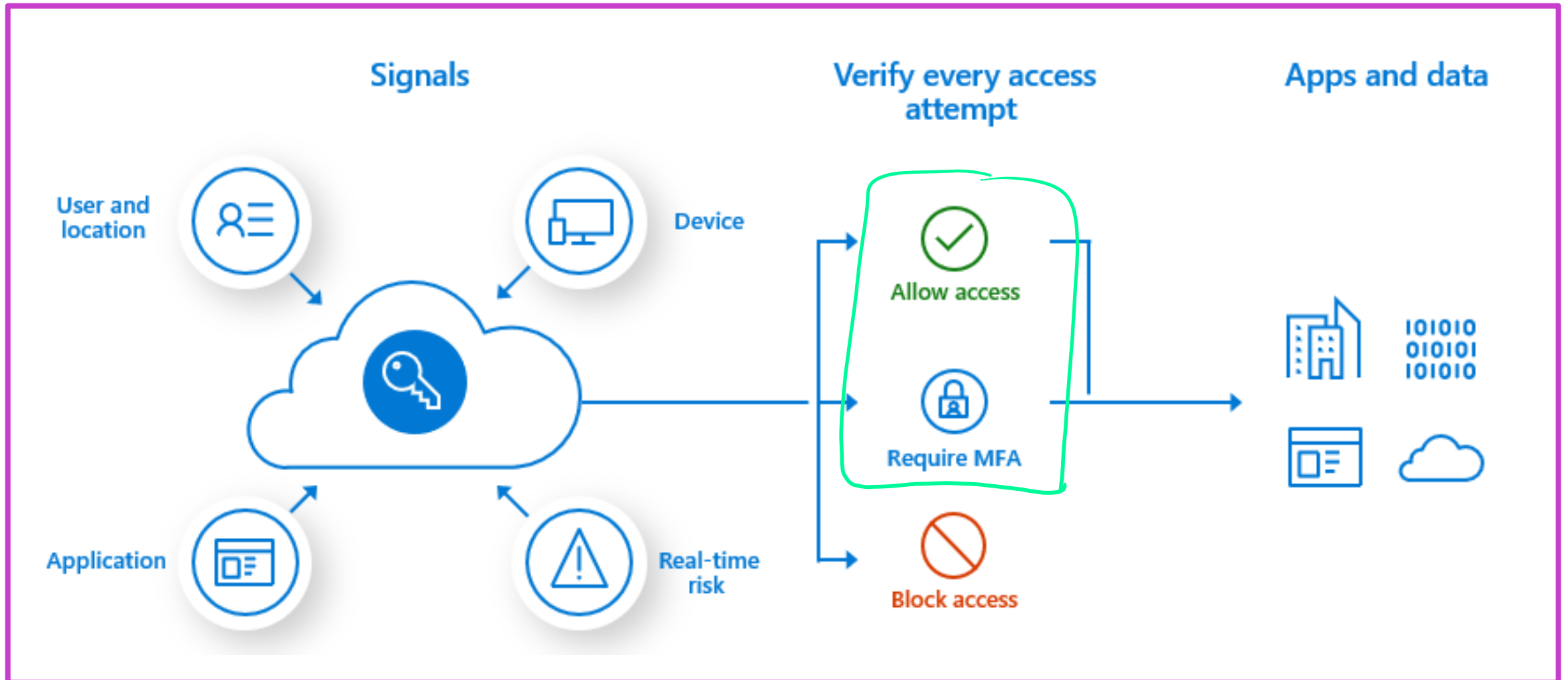
Enable Security defaults

☒ Yes ☐ No

Plan Conditional Access policies



About Conditional Access policies



Benefits of Conditional Access

- Increase productivity
- Manage risk
- Address compliance and governance
- Manage cost
- Zero Trust

Understanding Conditional Access policy components

New

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies.
[Learn more](#)

Name

Example: 'Device compliance app policy'

Assignments

Users

0 users and groups selected

Target resources

No target resources selected

Network

NEW

Not configured

Conditions

0 conditions selected

Access controls

Grant

0 controls selected

Session

0 controls selected

Control access based on signals from conditions like risk, device platform, location, client apps, or device state.
[Learn more](#)

User risk

User risk level is the likelihood that the user account is compromised.
[Not configured](#)

Sign-in risk

Sign-in risk level is the likelihood that the sign-in session is compromised.
[Not configured](#)

Insider risk

Insider risk assesses the user's risky data-related activity in Microsoft Purview Insider Risk Management.
[Not configured](#)

Device platforms

[Not configured](#)

Locations

[Not configured](#)

Client apps

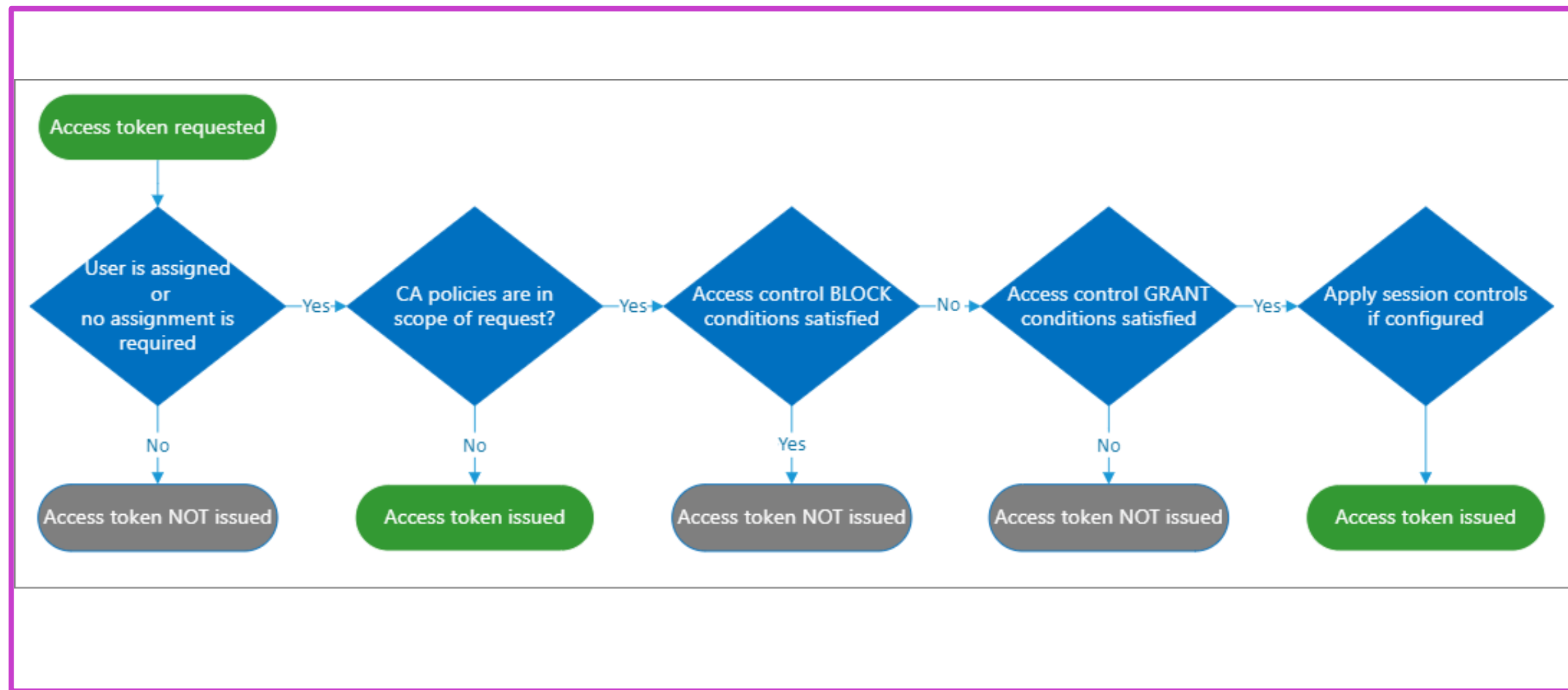
[Not configured](#)

Filter for devices

[Not configured](#)

© Copyright Microsoft Corporation. All rights reserved.

Access token issuance



Implement Conditional Access policies and assignments



Setting up Conditional Access

The screenshot displays the Microsoft Entra ID Conditional Access Overview page. A red arrow originates from the '+ Create new policy' button in the top navigation bar and points to the 'Create' button at the bottom right of the 'New' section.

Left Navigation Panel:

- Home >
- Conditional Access | Overview
- Overview
- Policies
- Insights and reporting
- Diagnose and solve problems
- Manage
 - Named locations
 - Custom controls (Preview)
 - Terms of use
 - VPN connectivity
 - Authentication contexts
 - Authentication strengths
 - Classic policies
- Monitoring
 - Sign-in logs
 - Audit logs
- Troubleshooting + Support
 - New support request

Overview Section:

- Getting started
- Overview
- Coverage
- Monitoring (Prev)

Policy Summary:

- Policy Snapshot**
 - 1 Enabled 0 Report-only 0 Off
 - [View all policies](#)
- Applications**
 - Browse a list of applications that are not protected by your policies.
 - [View top unprotected apps](#)

General Alerts:

- Named Locations**
 - Microsoft Entra ID now supports IPv6! Update your Named locations with IPv6 ranges. [Learn more](#)
 - 0 policies have a Named Location condition

Security Alerts (Preview)

New Section:

- Home > Conditional Access | Overview >
- New
- Conditional Access policy
- Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)
- Select what this policy applies to: Cloud apps
- Include** Exclude
 - ☐ None
 - ☐ All cloud apps
 - ☒ Select apps
- Edit filter (Preview): None
- Select: Office 365
- Access controls
 - Grant: 0 controls selected
 - Session: 0 controls selected
- Enable policy: Report-only On Off
- Create**

Grant/block access controls

Block access

- Use carefully or you could block your system
- Always test with What-if and Report-only mode

Grant access

- Enforce several different controls before allowing access

Note—require all/require one

The screenshot shows the 'Grant' configuration pane for a new Conditional Access policy. The left pane shows the policy configuration details, and the right pane shows the controls to be enforced.

Left Pane (New):

- Name:** Conditional Access Documentation ✓
- Assignments:**
 - Users and groups:** Specific users included
 - Cloud apps or actions:** 1 app included
 - Conditions:** 0 conditions selected
 - Access controls:**
 - Grant:** 0 controls selected
 - Session:** 0 controls selected
- Enable policy:** Report-only On **Off**
- Create** button

Right Pane (Grant):

- Select the controls to be enforced.**
 - ☐ Block access
 - ☒ Grant access
 - ☒ Require multi-factor authentication
 - ☐ Require device to be marked as compliant
 - ☐ Require Hybrid Azure AD joined device
 - ☐ Require approved client app
 - ☐ Require app protection policy (Preview)
- For multiple controls:**
 - ☒ Require all the selected controls
 - ☐ Require one of the selected controls
- Select** button

Session access control

Limit the experience of the user/application within a specific cloud application.

Base the experience on specific conditions the user has met or failed to meet.

New

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *

Example: 'Device compliance app policy'

Assignments

Users ①

0 users and groups selected

Target resources ①

No target resources selected

Network **NEW** ①

Not configured

Conditions ①

0 conditions selected

Access controls

Grant ①

0 controls selected

Session ①

0 controls selected

Enable policy

Report-only On Off

Create

Session

Control access based on session controls to enable limited experiences within specific cloud applications. [Learn more](#)

☐ Use app enforced restrictions ①

i This control only works with supported apps. Currently, Office 365, Exchange Online, and SharePoint Online are the only cloud apps that support app enforced restrictions. [Learn more](#)

☐ Use Conditional Access App Control ①

☐ Sign-in frequency ①

☐ Persistent browser session ①

☐ Customize continuous access evaluation ①

☐ Disable resilience defaults ①

☐ Require token protection for sign-in sessions (Preview) ①

☐ Use Global Secure Access security profile ①

i This option only works with Global Secure Access resources.

Select

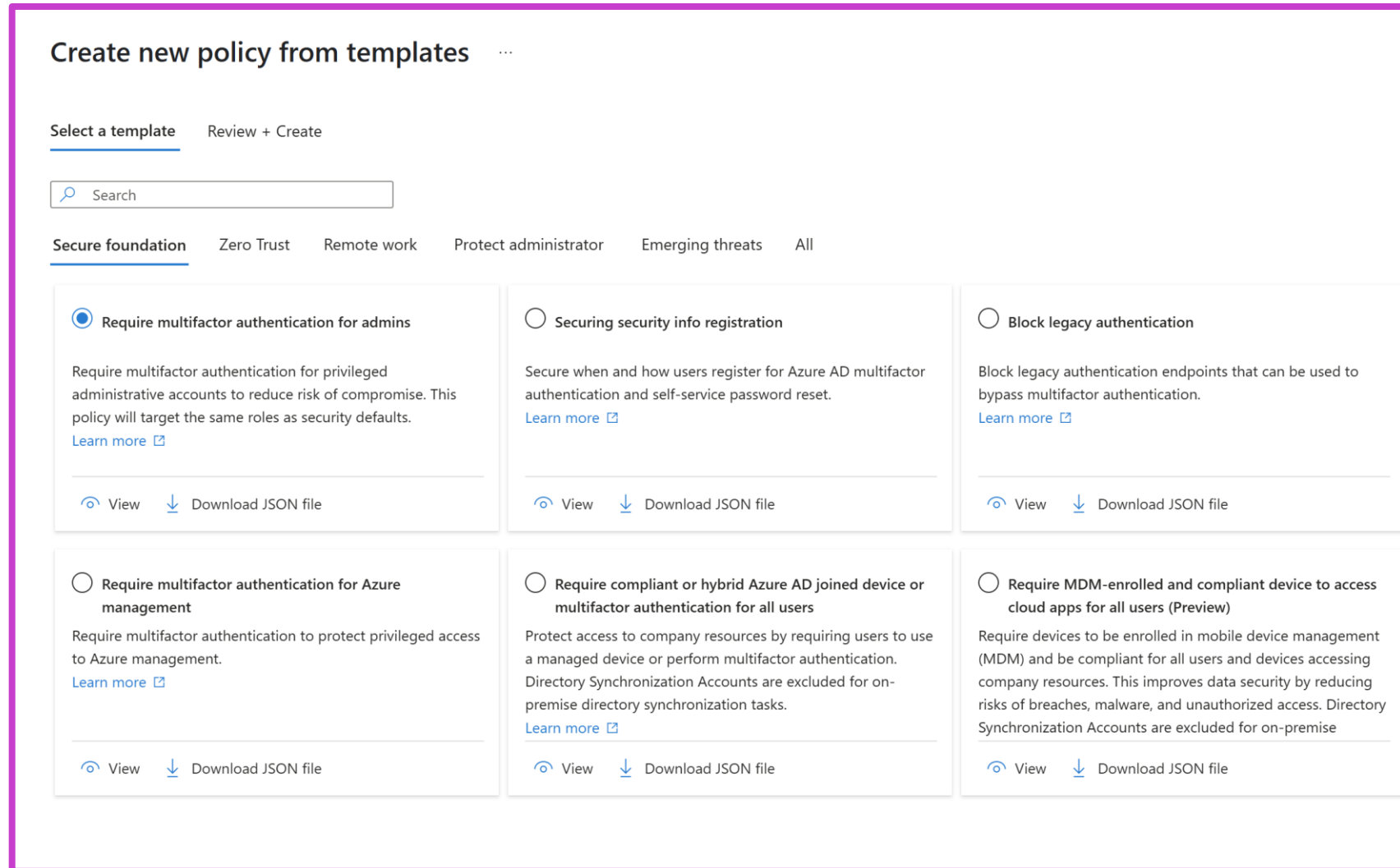
Template-based Conditional Access



Conditional Access templates

There are 14 policy templates available:

1. Open Microsoft admin center.
2. View the Identity menu.
3. Open the Protection section.
4. Choose Conditional Access.
5. Create new policy from template.



Examples of Conditional Access scenarios

- Require registration from a trusted location
- Block access by location
- Require compliant devices
- Exclude access from emergency and service accounts

Conditional Access terms of use (TOU)

New terms of use ...

Terms of use

Create and upload documents

Name * ⓘ

Example: 'All users terms of use'

Terms of use document * ⓘ

Upload required PDF



Select default language



Display name

[+ Add language](#)

Require users to expand the terms of use ⓘ

On

Off

Require users to consent on every device ⓘ

On

Off

Expire consents ⓘ

On

Off

Duration before re-acceptance required (days) ⓘ

Example: '90'

Conditional access

Enforce with conditional access policy templates * ⓘ

Policy templates



Exercise—implement conditional access policies, roles, and assignments



Microsoft Entra Conditional Access is an advanced feature of Microsoft Entra ID that allows you to specify detailed policies that control who can access your resources. This exercise teaches students how to create and test a Conditional Access policy.

[Launch this Exercise in GitHub](#)

Name *

Example: 'Device compliance app policy'

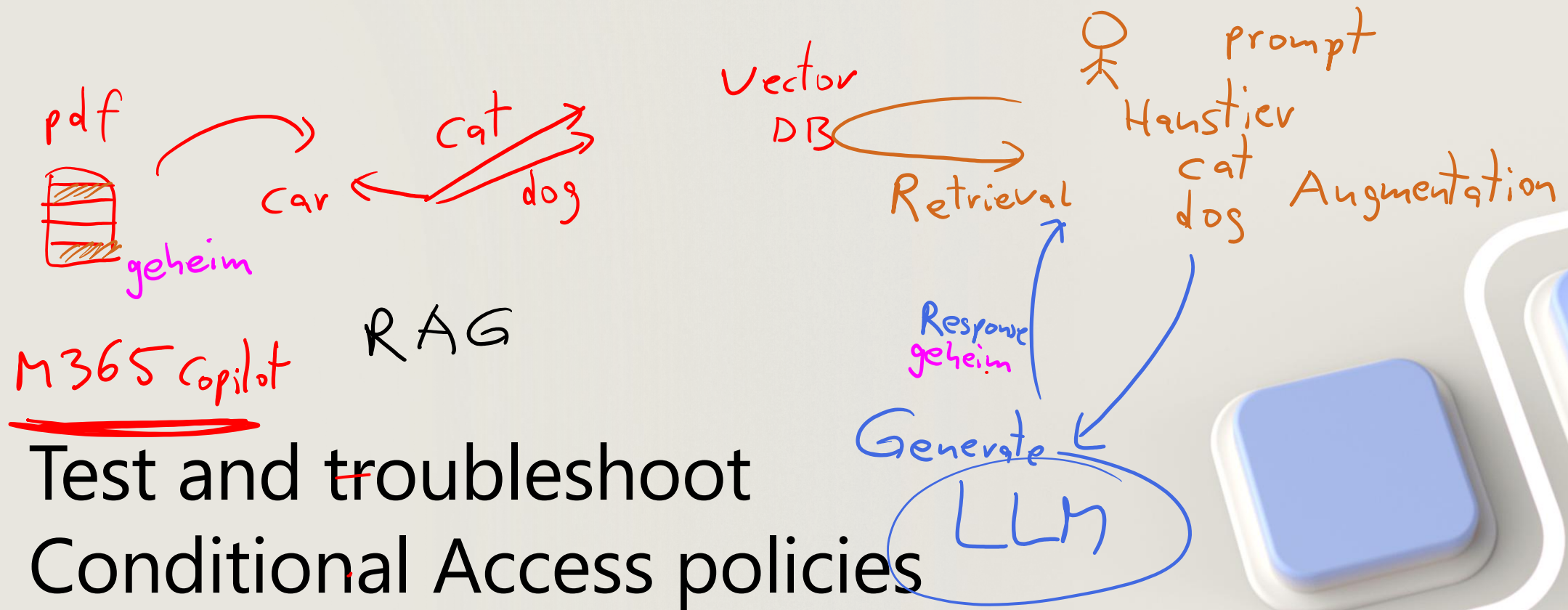
Assignments

Users ⓘ
0 users and groups selected

Target resources ⓘ
No target resources selected

Network **NEW** ⓘ
Not configured

Conditions ⓘ
0 conditions selected



Configurations to avoid

For all users, all cloud apps:

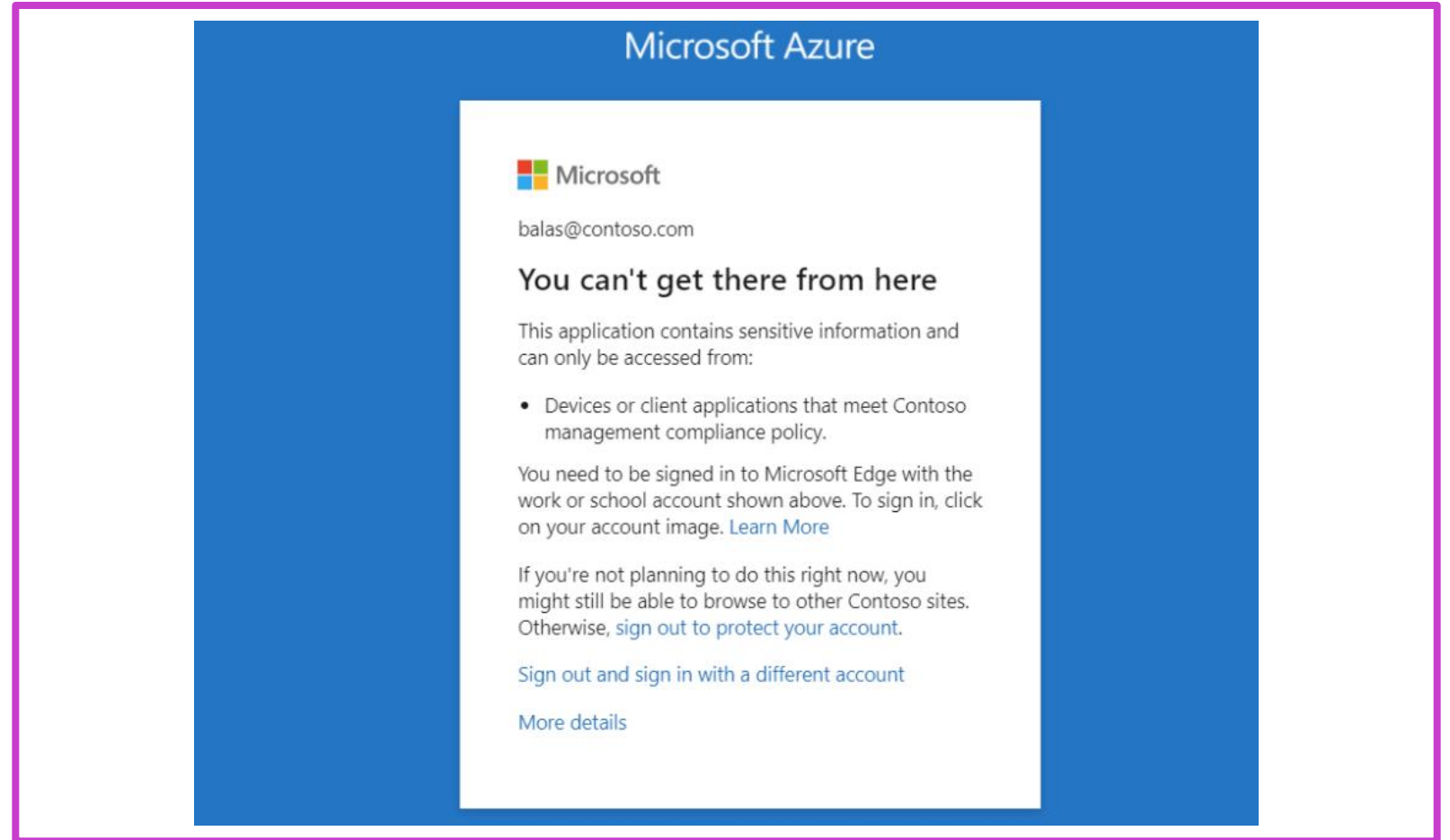
- Block access
- Require device to be marked as compliant
- Require Hybrid Microsoft Entra ID domain-joined device
- Require app protection policy

For all users, all cloud apps, all platforms:

- Block access

Troubleshooting sign-in interrupts

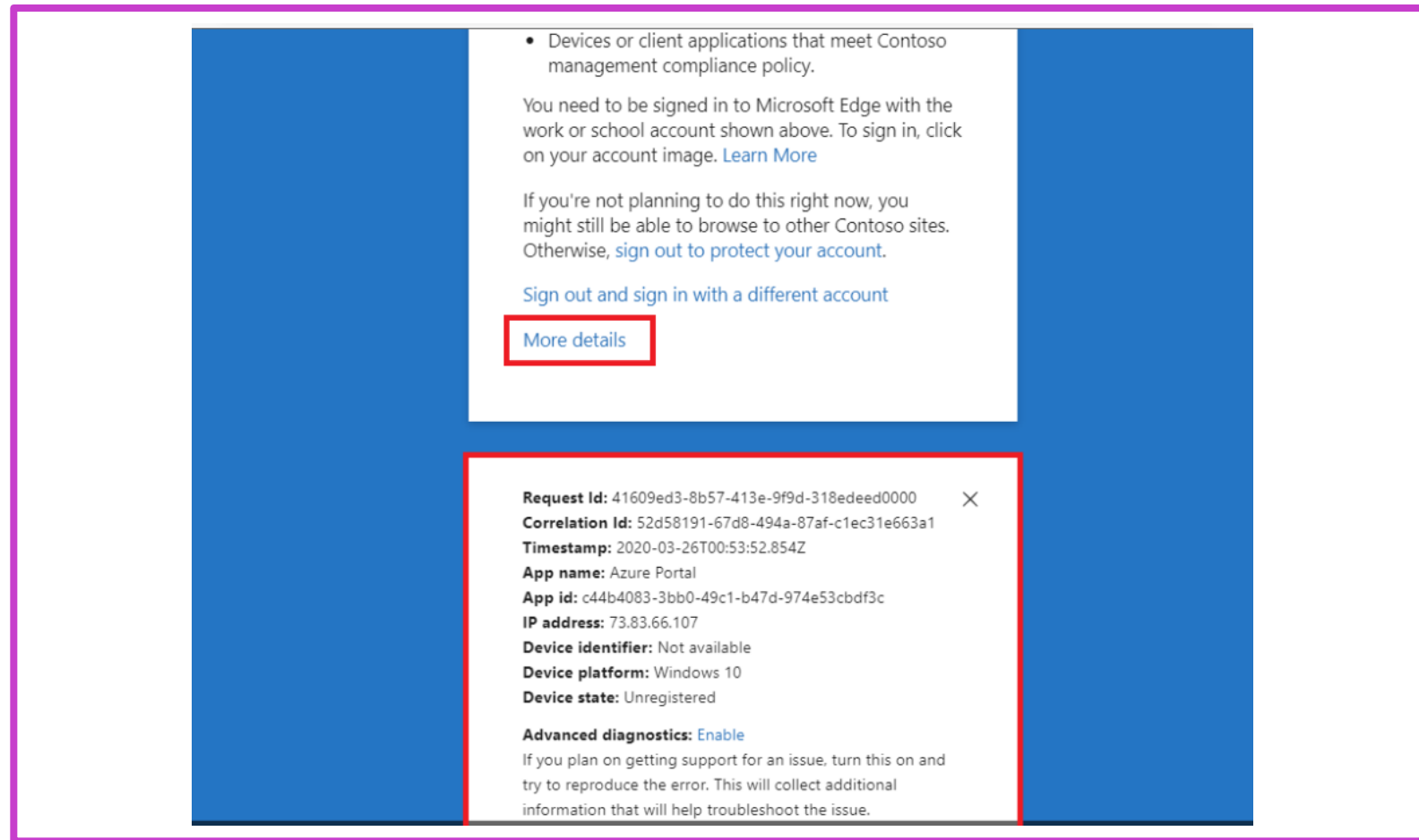
In this error, the message states that the application can only be accessed from devices or client applications that meet the company's mobile device management policy. In this case, the application and device do not meet that policy.



Troubleshooting directory sign-in events

Find more information about the problem by clicking **More Details** in the initial error page.

Clicking **More Details** will reveal troubleshooting information that is helpful when searching the Microsoft Entra sign-in events for the specific failure event the user saw, or when opening a support incident with Microsoft.



Implement application controls



Conditional Access App Control

- Block download, cut, copy and print
- Enforce document labeling with Azure Information Protection
- Prevent file uploads
- Monitor/log sessions for compliance
- Block app access based on risk factors

Home > Conditional Access | Overview >

New

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *

Example: 'Device compliance app policy'

Assignments

Users ⓘ

0 users and groups selected

Target resources ⓘ

No target resources selected

Conditions ⓘ

0 conditions selected

Access controls

Grant ⓘ

0 controls selected

Session ⓘ

0 controls selected

Enable policy

Report-only On Off

Create

Session

Control access based on session controls to enable limited experiences within specific cloud applications. [Learn more](#)

☐ Use app enforced restrictions ⓘ

☐ Use Conditional Access App Control ⓘ

☐ Sign-in frequency ⓘ

☐ Persistent browser session ⓘ

☐ Customize continuous access evaluation ⓘ

☐ Disable resilience defaults ⓘ

☐ Require token protection for sign-in sessions (Preview) ⓘ

Select

Info: This control only works with supported apps. Currently, Office 365, Exchange Online, and SharePoint Online are the only cloud apps that support app enforced restrictions. [Learn more](#)

CA-App Control works with Microsoft Defender for Cloud Apps

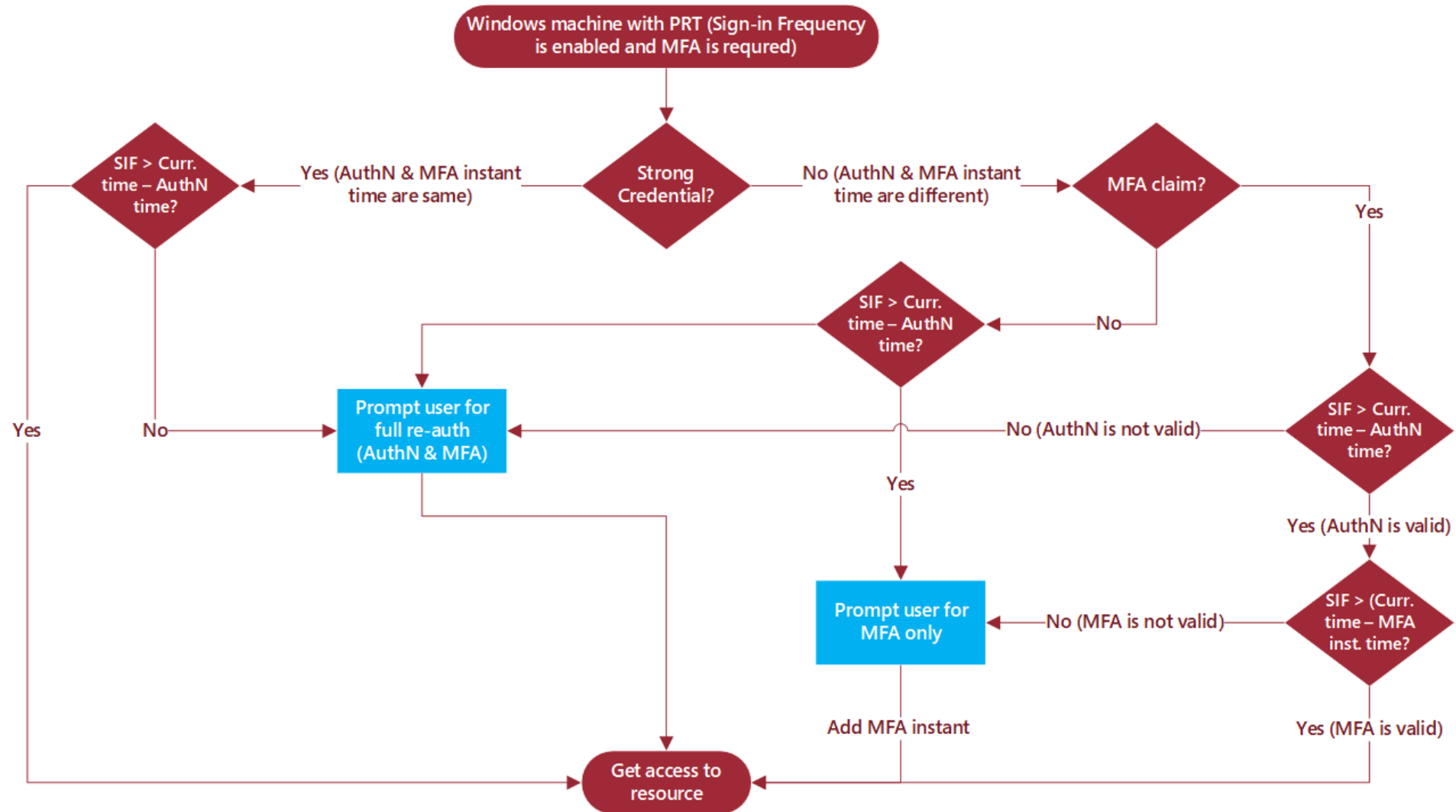
Benefits of using app protection policies (MDM/MAM)

- Protecting your company data at the app level
- End-user productivity isn't affected, and policies don't apply when using the app in a personal context
- App protection policies ensure that the app-layer protections are in place
- MDM, in addition to MAM, ensures that the device is protected

Implement session management



User sign-in frequency and multifactor authentication



Validation

Use the What If tool:

- Simulate a login from the user to the target application
- Select other conditions based on how you configured your policy.

The authentication session management controls show up in the result of the tool.

What If ...

Policies

[Info](#) | [Got feedback?](#)

Test the impact of Conditional Access on a user when signing in under certain conditions. [Learn more](#)

User or Workload identity ⓘ

[Patti Fernandez](#)

Cloud apps, actions, or authentication context ⓘ

1 app selected

IP address ⓘ

Enter IP address (ex: 40.77.182.32)

Country ⓘ

Select country...

Device platform ⓘ

Select device platform...

Client apps ⓘ

Select a client app...

Device state (deprecated) ⓘ

Select device state...

Sign-in risk ⓘ

Select sign-in risk...

User risk ⓘ

Select user risk...

Service principal risk ⓘ

Select service principal risk...

Select what this policy applies to

Cloud apps

- ☐ Any cloud app
- ☒ Select apps

Select

[Microsoft Admin Portals \(Preview\)](#)



Microsoft Admin Portals (Previe... ⋮

Exercise—configure authentication session controls



This exercise teaches the student to configure sign-in frequency controls using a conditional access policy.

[Launch this Exercise in GitHub](#)

The screenshot shows the 'Conditional Access | Overview' page in the Microsoft Entra ID console. The page is titled 'Conditional Access | Overview' with a sub-header 'Microsoft Entra ID'. On the left, there is a navigation pane with the following items: 'Overview' (selected), 'Policies', 'Insights and reporting', 'Diagnose and solve problems', and a 'Manage' section containing 'Named locations', 'Custom controls (Preview)', 'Terms of use', and 'VPN connectivity'. The main content area has a top bar with links: '+ Create new policy', '+ Create new policy from templates', 'Refresh', and 'Got feedback?'. Below this is a tabbed interface with 'Getting started', 'Overview' (selected), 'Coverage', 'Monitoring (Preview)', and 'Tutorials'. The 'Overview' tab displays a 'Policy Summary' section with a 'Policy Snapshot' showing '5 Enabled', '1 Report-only', and '0 Off' policies, with a link to 'View all policies'. To the right, there is a 'Users' section showing '2 users signed in during the last 7 days without any policy coverage' and a link to 'See all unprotected sign-ins'.

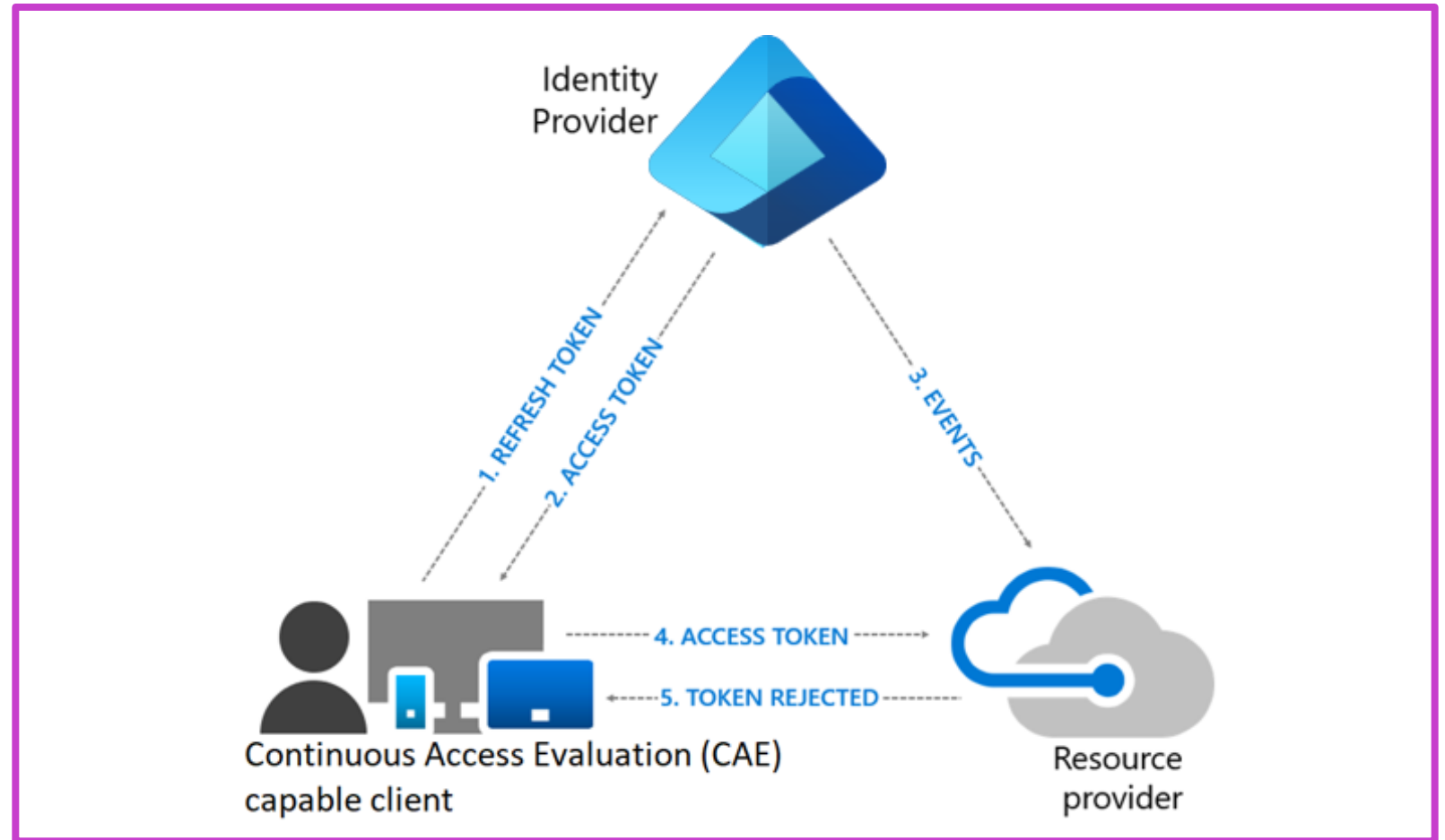
Continuous access evaluation



Continuous access evaluation

Benefits

- There are several key benefits to continuous access evaluation.
- User termination or password change/reset: User session revocation will be enforced in near real time.
- Network location change: Conditional Access location policies will be enforced in near real time.
- Token export to a machine outside of a trusted network can be prevented with Conditional Access location policies.

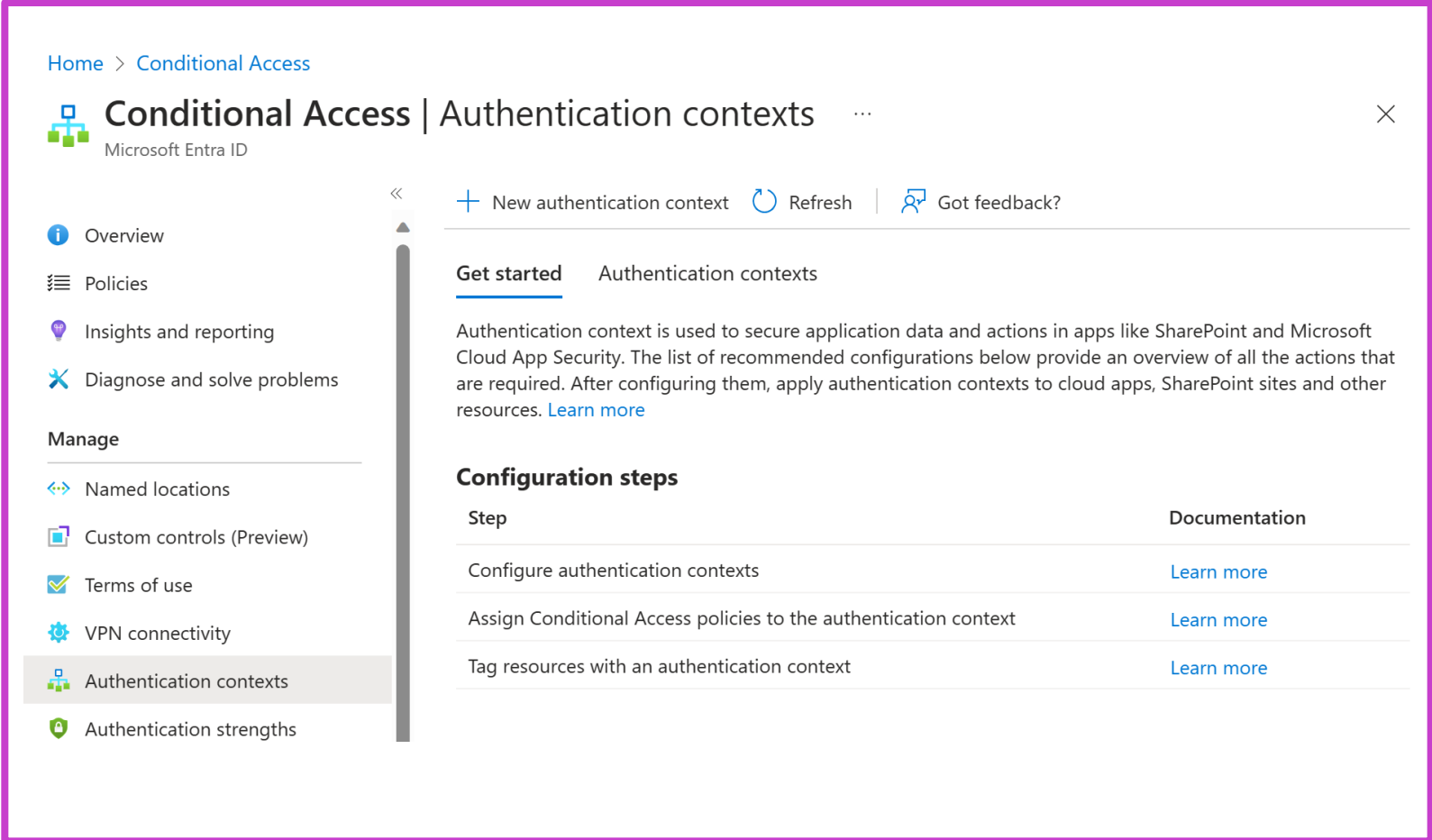


Authentication context



Configure authentication context—Conditional Access

Authentication context can be used to further secure data and actions in applications. These applications can be your own custom applications, custom line-of-business (LOB) applications, applications like SharePoint, or applications protected by Microsoft Defender for Cloud Apps.



The screenshot shows the Microsoft Entra ID Conditional Access | Authentication contexts page. The left sidebar contains navigation links: Overview, Policies, Insights and reporting, Diagnose and solve problems, Manage (with a sub-menu), Named locations, Custom controls (Preview), Terms of use, VPN connectivity, Authentication contexts (highlighted), and Authentication strengths. The main content area has a header with 'Conditional Access | Authentication contexts' and a Microsoft Entra ID logo. Below the header, there are links for 'New authentication context', 'Refresh', and 'Got feedback?'. The 'Get started' section provides an overview of authentication context and a 'Learn more' link. The 'Configuration steps' section is a table with three rows: 'Configure authentication contexts', 'Assign Conditional Access policies to the authentication context', and 'Tag resources with an authentication context', each with a corresponding 'Learn more' link.

Home > Conditional Access

Conditional Access | Authentication contexts

Microsoft Entra ID

Overview

Policies

Insights and reporting

Diagnose and solve problems

Manage

Named locations

Custom controls (Preview)

Terms of use

VPN connectivity

Authentication contexts

Authentication strengths

+ New authentication context Refresh Got feedback?

Get started Authentication contexts

Authentication context is used to secure application data and actions in apps like SharePoint and Microsoft Cloud App Security. The list of recommended configurations below provide an overview of all the actions that are required. After configuring them, apply authentication contexts to cloud apps, SharePoint sites and other resources. [Learn more](#)

Configuration steps

Step	Documentation
Configure authentication contexts	Learn more
Assign Conditional Access policies to the authentication context	Learn more
Tag resources with an authentication context	Learn more

References (1 of 2)

What is Conditional Access?

<https://www.youtube.com/watch?v=ffMAw2IVO7A>

How to deploy Conditional Access

https://www.youtube.com/watch?v=c_izlRNjNuk

How to roll out CA policies to end users

https://www.youtube.com/watch?v=0_Fze7Zpyvc

Conditional Access with device controls

<https://www.youtube.com/watch?v=NcONUf-jeS4>

Conditional Access with Microsoft Entra MFA

<https://www.youtube.com/watch?v=Tbc-SU97G-w>



References (2 of 2)

Conditional Access in Enterprise Mobility and Security

<https://www.youtube.com/watch?v=A7IrxAH87wc>

Using the location condition in a Conditional Access policy

<https://learn.microsoft.com/azure/active-directory/conditional-access/location-condition>

Use compliance policies to set rules for devices you manage with Intune

<https://learn.microsoft.com/mem/intune/protect/device-compliance-get-started>

Introducing security defaults

<https://techcommunity.microsoft.com/t5/azure-active-directory-identity/introducing-security-defaults/ba-p/1061414>

Plan a Conditional Access deployment

<https://techcommunity.microsoft.com/t5/azure-active-directory-identity/introducing-security-defaults/ba-p/1061414>



Manage Microsoft Entra Identity Protection

P1



Objectives

- 1 Review identity protection basics
- 2 Implement and manage user risk policy
- 3 Implement MFA registration policy
- 4 Monitor, investigate, and remediate elevated risky users
- 5 Security for workload identities
- 6 Microsoft Defender for Identity

Review identity protection basics



Identity protection basics

Identity protection is a service that enables organizations to view the security posture of any account.

Key tasks:

- Automate the detection and remediation of identity-based risks.
- Investigate risks using data in the Microsoft Entra admin center.
- Export risk detection data to third-party utilities for further analysis.

Risk detection, remediation, and investigation

Common risks detected and remediated

- Anonymous IP address/atypical travel
- Malware-linked IP address
- Unfamiliar sign-in properties
- Leaked credentials
- Password spray
- Microsoft Entra threat intelligence
- New country
- Suspicious inbox forwarding

Risk investigation

Reports:

- Risky users
- Risky sign-ins
- Risk detections

Risk levels—low/medium/high

- Each level represents a higher likelihood that a user or sign-in is compromised

Licensing for Identity Protection

Capability		Microsoft Entra ID Free/ Microsoft 365 Apps	Microsoft Entra ID Premium P1	Microsoft Entra ID Premium P2
User risk policy (via Identity Protection)		No	No	Yes
Sign-in risk policy (via identity protection)		No	No	Yes
Security reports	Overview	No	No	Yes
	Risky users	Limited Information. *	Limited Information.*	Full access
	Risky sign-ins	Limited Information. *	Limited Information. *	Full access
	Risk detection	No	Limited Information. *	Full access
Notifications	User at risk alert	No	No	Yes
	Weekly digest	No	No	Yes
MFA registration policy		No	No	Yes

* See notes or student materials for details.

Identity Protection permissions

Role	Can do	Cannot do
Global Administrator	Full access to Identity Protection	
Security Administrator	Full access to Identity Protection	Reset password for a user
Security Operator	View all Identity Protection reports and Overview blade Dismiss user risk, confirm safe sign-in, confirm compromise	Configure or change policies Reset password for a user Configure alerts
Security Reader	View all Identity Protection reports and Overview blade	Configure or change policies Reset password for a user Configure alerts Give feedback on detections

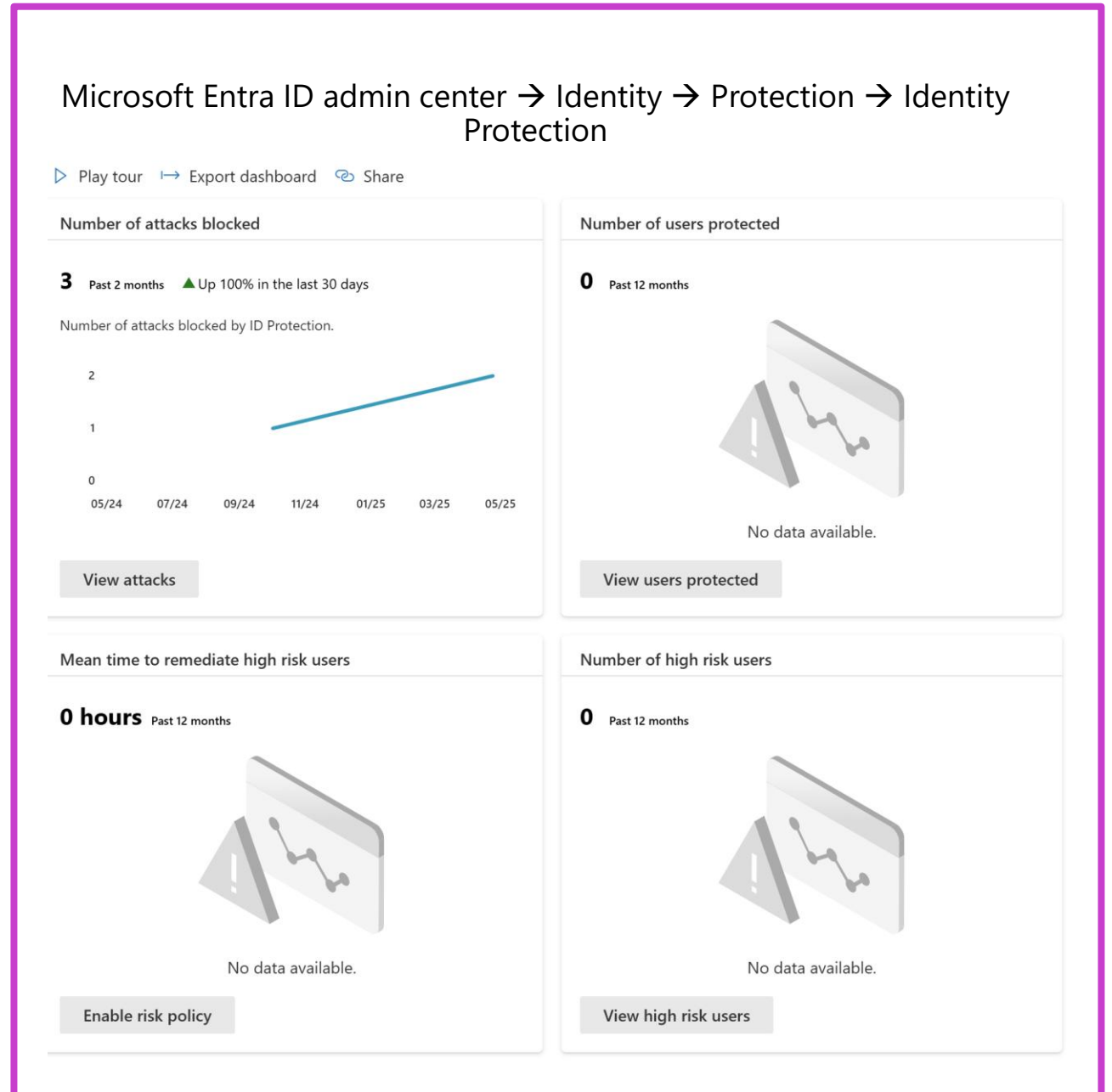
Microsoft Entra ID P2 license required

Implement and manage user risk policy



User risk policies

- Both sign-in risk policies and user risk policies can be enabled to automate the response to risk detections and allow users to self-remediate.
- Organizations must decide the level of risk they are willing to accept, balancing user experience and security posture.



Exercise—enable sign-in risk policy



This exercise teaches students to enable a user risk policy and a sign-in risk policy.

[Launch this Exercise in GitHub](#)

Identity Protection | Sign-in risk policy

Dashboard (Preview)

Overview

Tutorials

Diagnose and solve problems

Protect

User risk policy

Sign-in risk policy

Multifactor authentication registration policy

Report

Risky users

Risky workload identities

We recommend migrating sign-in risk policy to

Policy Name

Sign-in risk remediation policy

Assignments

Users

All users

Sign-in risk

Medium and above

Controls

Access

Require multifactor authentication

Implement MFA registration policy



What is MFA registration policy?

Microsoft Entra multifactor authentication provides a means to verify who you are using more than just a username and password. It provides a second layer of security to user sign-ins. For users to be able to respond to MFA prompts, they must first register for Microsoft Entra multifactor authentication.

We recommend that you require Microsoft Entra multifactor authentication for user sign-ins because it:

- Delivers strong authentication through a range of verification options.
- Plays a key role in preparing your organization to self-remediate from risk detections in Identity Protection.

Demo—configure Microsoft Entra multifactor authentication registration policy



Microsoft Entra multifactor authentication provides a means to verify who you are using more than just a username and password. It provides a second layer of security to user sign-ins. This exercise teaches students to configure a registration policy.

[Launch this Exercise in GitHub](#)

The screenshot displays the Microsoft Entra Identity Protection console. The breadcrumb navigation shows 'Home > Identity Protection'. The main heading is 'Identity Protection | Multifactor authentication registration policy'. On the left sidebar, there is a search bar and a list of navigation items: 'Dashboard (Preview)', 'Overview', 'Tutorials', 'Diagnose and solve problems', and a 'Protect' section containing 'User risk policy', 'Sign-in risk policy', and 'Multifactor authentication registration policy' (which is highlighted). The main content area on the right shows the configuration for the 'Multifactor authentication registration policy'. It includes a 'Policy Name' field with the value 'Multifactor authentication registration policy', an 'Assignments' section with a link to 'All users', and a 'Controls' section with a checked checkbox for 'Require Microsoft Entra ID multifactor authentication registration'.

Monitor, investigate,
and remediate elevated
risky users



Risk reports

Each report launches with a list of all detections for the period shown at the top of the report. Each report allows for the addition or removal of columns based on administrator preference. Administrators can choose to download the data in .CSV or .JSON format. Reports can be filtered using the filters across the top of the report

 Identity Protection | Risky sign-ins

[Download](#) [Learn more](#) [Export Data Settings](#) [Configure trusted IPs](#) [Troubleshoot](#) [Select all](#)

We recommend migrating Identity Protection policies to Conditional Access for more conditions and controls. [Learn more](#)

Auto refresh : **Off** Date : **Last 1 month** Show dates as : **Local** Risk state : **2 selected**

Risk level (real-time) : **None Selected** Risk level (aggregate) : **None Selected** Detection type(s) : **None Selected**

Sign-in Type : **2 selected** [Add filters](#)

☐ Date ↑↓	User ↑↓	IP address	Location	Risk state ↑↓
☐ 8/8/2024, 4:28:24 PM	Iker Grgic	2806:2f0:9380:f019:2d...	MX	At risk
☐ 8/8/2024, 10:55:13 AM	Nikolajs Lusi	192.0.2.30	Bengaluru, Karnataka, IN	At risk
☐ 8/8/2024, 2:09:19 AM	Shanequa Gihon (Corp M)	223.233.80.8	Pune, Maharashtra, IN	At risk
☐ 8/7/2024, 12:34:34 PM	Shanequa Gihon (Corp M)	203.0.113..144	Chas, Jharkhand, IN	At risk
☐ 8/7/2024, 4:07:15 AM	Nikolajs Lusi	192.0.2.30	Bengaluru, Karnataka, IN	At risk
☐ 8/5/2024, 5:22:41 AM	Shanequa Gihon (Corp M)	198.51.100.143	Hyderabad, Telangana, IN	At risk
☐ 8/2/2024, 5:28:54 AM	Shanequa Gihon (Corp M)	198.51.100.28	Hyderabad, Telangana, IN	At risk
☐ 8/2/2024, 3:02:46 AM	Shanequa Gihon (Corp M)	192.0.2.119	Ranchi, Jharkhand, IN	At risk
☐ 8/2/2024, 3:00:39 AM	Shanequa Gihon (Corp M)	192.0.2.119	Ranchi, Jharkhand, IN	At risk
☐ 8/2/2024, 2:59:50 AM	Shanequa Gihon (Corp M)	192.0.2.119	Ranchi, Jharkhand, IN	At risk
☐ 8/2/2024, 2:58:19 AM	Shanequa Gihon (Corp M)	192.0.2.119	Ranchi, Jharkhand, IN	At risk
☐ 8/2/2024, 2:57:11 AM	Shanequa Gihon (Corp M)	192.0.2.119	Ranchi, Jharkhand, IN	At risk
☐ 8/2/2024, 2:42:08 AM	Shanequa Gihon (Corp M)	198.51.100.81	Hyderabad, Telangana, IN	At risk
☐ 8/1/2024, 1:30:23 AM	Shanequa Gihon (Corp M)	198.51.100.30	Hyderabad, Telanqana, IN	At risk

Report details—example Risky Users Report

Risky users

Learn more

Download

Unselect all

Confirm user(s) compromised

Confirm user(s) safe

Dismiss user(s) risk

Refresh

Want to allow automatic risk remediation? Setup risk policies in Conditional Access. Learn more

Get help investigating a risky user with Copilot. Select a user to get started.

Auto refresh : Off

Show dates as : Local

Risk level : High

Add filters

User	Risk state	Risk last updated
Michael G Scott	At risk	7/23/2024, 8:06:02 PM
Toby Adeniyi	At risk	6/7/2024, 4:09:40 PM
Lee Gu	At risk	5/23/2024, 1:36:46 AM
Oksana Avira	At risk	4/17/2024, 10:36:10 AM
Cameron Potter	At risk	4/11/2024, 12:07:11 PM
Garima Maheshwari	At risk	4/1/2024, 2:24:08 PM
Admin Lab	At risk	2/29/2024, 3:59:46 AM
Jonathan Wolcott	At risk	2/26/2024, 6:03:15 AM
Cam Morales	At risk	9/18/2023, 7:53:06 AM
Malka Bunnell (Corp)	At risk	8/30/2023, 4:17:02 PM
-	At risk	9/28/2022, 3:53:58 PM
-	At risk	2/22/2022, 7:17:56 PM
-	At risk	2/22/2022, 7:17:56 PM
-	At risk	2/22/2022, 7:17:55 PM
-	At risk	2/22/2022, 7:17:55 PM

© Copyright Microsoft Corporation. All rights reserved.

Remediate risks and unblock users

Administrators have the following options to remediate:

- Self-remediation with risk policy
- Manual password reset
- Dismiss user risk
- Close individual risk detections manually

Copilot for Security + Microsoft Entra – Risky Users

The screenshot shows the Microsoft Entra Identity Protection interface. The left navigation pane has 'Identity Protection' selected. The main content area is titled 'Identity Protection | Risky users'. It includes a search bar, a list of navigation links (Dashboard, Overview, Tutorials, Diagnose and solve problems), and a 'Protect' section with links to Conditional Access, User risk policy, Sign-in risk policy, and Multifactor authentication registration policy. Below these is a 'Report' section with links to Risky users, Risky workload identities, Risky sign-ins, and Risk detections. The 'Risky users' link is highlighted. The main content area also features a table of risky users with columns for User, Risk state, and Risk last updated. The first user, Giovanna Costa, is highlighted with a red box.

User	Risk state	Risk last updated
Giovanna Costa	At risk	3/26/2024, 4:06:02 PM
Ratih Winata	At risk	3/26/2024, 11:31:01 AM
Sascha Lange	At risk	3/26/2024, 7:21:32 AM

CRUD

Use the Microsoft Graph API

- Microsoft Graph—unified API endpoint and the home of Microsoft Entra Identity Protection APIs
- Three Microsoft Graph APIs expose information about risky users and sign-ins:
 - RiskDetection
 - RiskyUsers
 - SignIn

The screenshot displays the Microsoft Graph Explorer interface. At the top, the Microsoft logo and navigation links are visible. The main area is divided into a left sidebar and a right pane. The sidebar, titled 'Graph Explorer', shows the user 'MOD Administrator' and a list of sample queries under 'Getting Started (8)'. The first query, 'GET my profile', is circled in red. The right pane shows the details of the selected query. The HTTP method is 'GET', and the URL is 'https://graph.microsoft.com/v1.0/me/'. The 'Run query' button is also circled in red. Below the URL bar, the 'Request body' tab is active, showing an empty JSON object. The 'Response preview' tab at the bottom shows the JSON response for the user profile, including fields like '@odata.context', 'businessPhones', 'displayName', 'givenName', 'jobTitle', and 'mail'. A status bar at the bottom indicates 'OK - 200 - 180ms'.

Security for workload identities

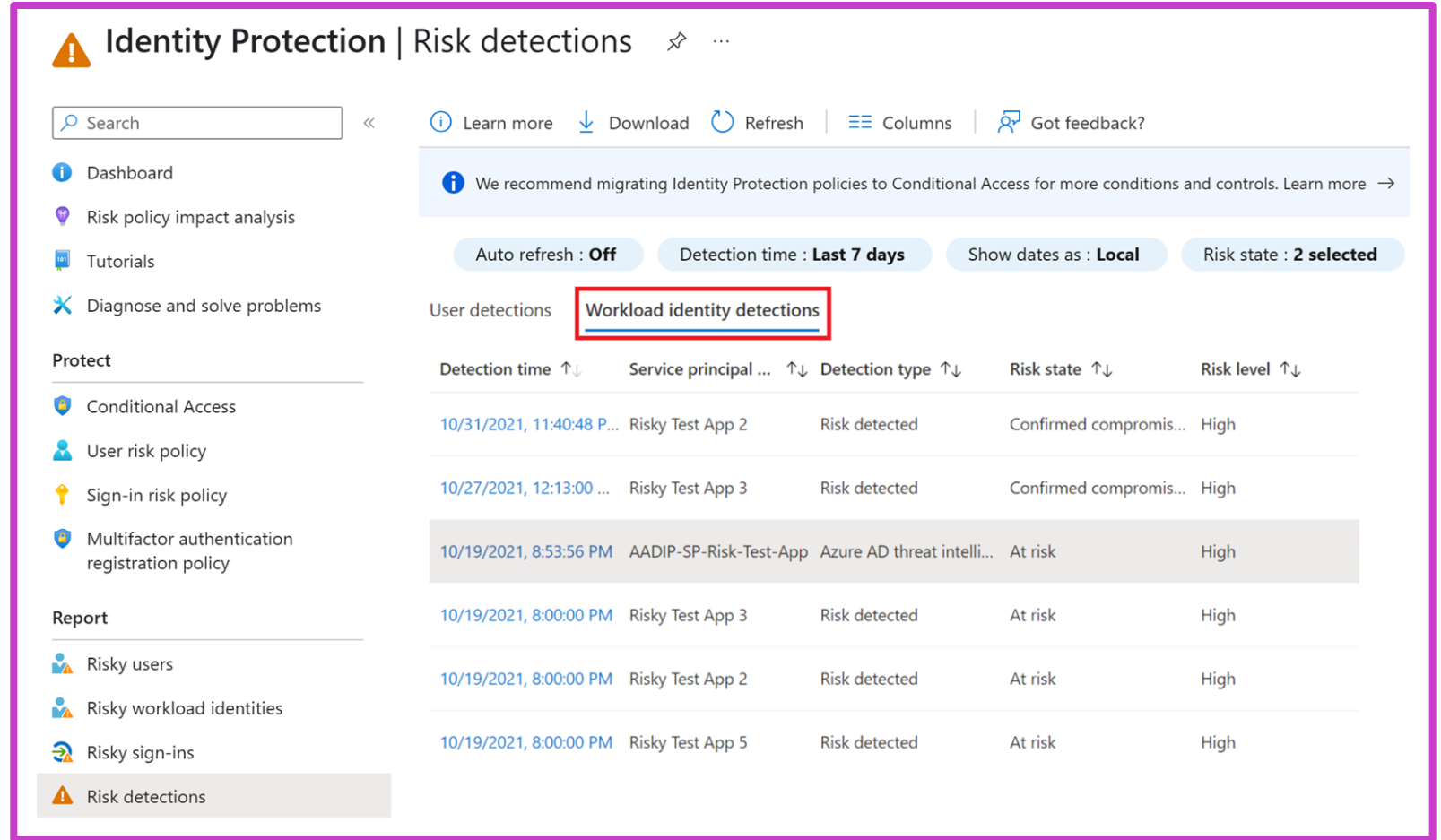


Workload identities risk

A workload identity allows an application or service principal access to resources.

These workload identities differ from traditional user accounts as they:

- Can't perform multifactor authentication.
- Often have no formal lifecycle process.
- Need to store their credentials or secrets.



Identity Protection | Risk detections

Search << >> Learn more Download Refresh Columns Got feedback?

We recommend migrating Identity Protection policies to Conditional Access for more conditions and controls. Learn more →

Auto refresh : Off Detection time : Last 7 days Show dates as : Local Risk state : 2 selected

User detections **Workload identity detections**

Detection time ↑↓	Service principal ... ↑↓	Detection type ↑↓	Risk state ↑↓	Risk level ↑↓
10/31/2021, 11:40:48 P...	Risky Test App 2	Risk detected	Confirmed compromis...	High
10/27/2021, 12:13:00 ...	Risky Test App 3	Risk detected	Confirmed compromis...	High
10/19/2021, 8:53:56 PM	AADIP-SP-Risk-Test-App	Azure AD threat intelli...	At risk	High
10/19/2021, 8:00:00 PM	Risky Test App 3	Risk detected	At risk	High
10/19/2021, 8:00:00 PM	Risky Test App 2	Risk detected	At risk	High
10/19/2021, 8:00:00 PM	Risky Test App 5	Risk detected	At risk	High

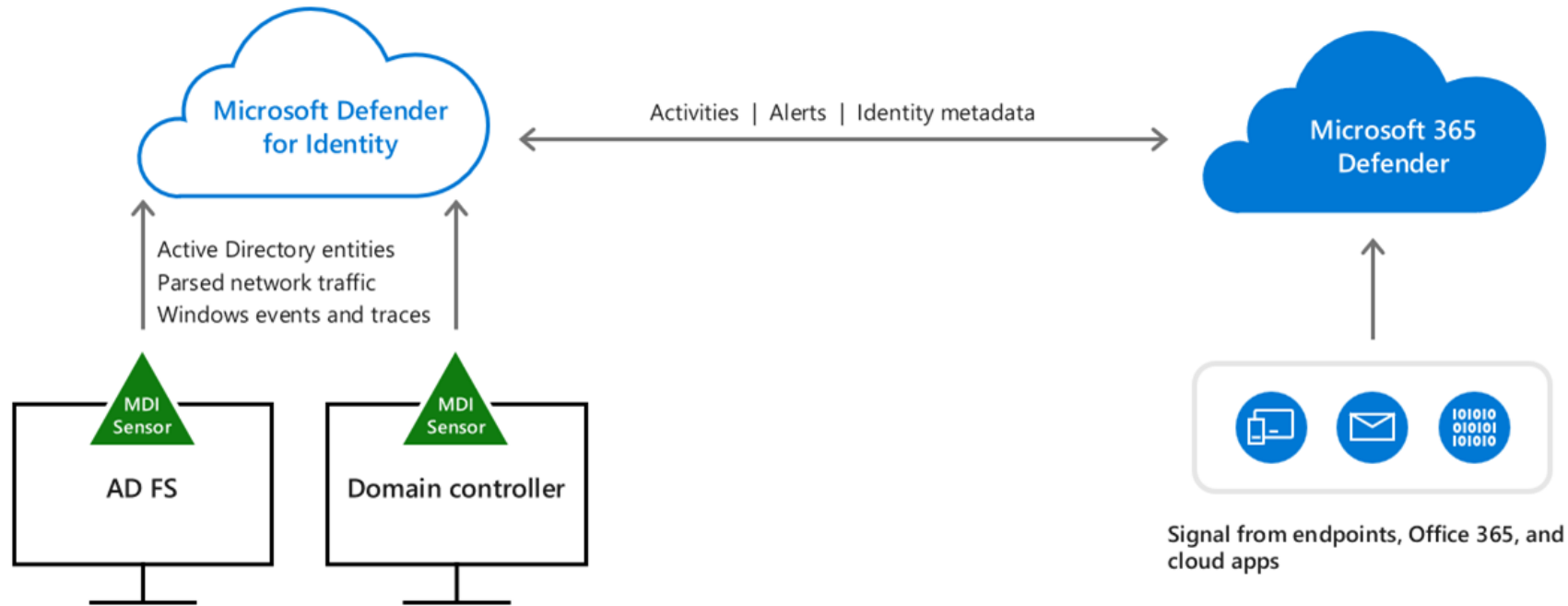
Workload identity risks detected

Detection name	Description
Microsoft Entra threat intelligence	This risk detection indicates some activity that is consistent with known attack patterns based on Microsoft's internal and external threat intelligence sources.
Suspicious sign-ins	This risk detection indicates sign-in properties or patterns that are unusual for this service principal.
Unusual addition of credentials to an OAuth app	This detection identifies the suspicious addition of privileged credentials to an OAuth app. This can indicate that an attacker has compromised the app, and is using it for malicious activity.
Admin confirmed account compromised	This detection indicates an admin has selected 'Confirm compromised' in the Risky Workload Identities UI or using the riskyServicePrincipals API.

Microsoft Defender for Identity



Microsoft Defender for Identity



- Monitor users, entity behavior, and activities with learning-based analytics
- Protect user identities and credentials stored in Active Directory
- Identify and investigate suspicious user activities and advanced attacks throughout the kill chain
- Provide clear incident information on a simple timeline for fast triage

Log into Defender for Identity:

- <https://security.microsoft.com/settings/identities>

What Microsoft Defender for Identity does

- **Monitors**

- AD on-premises and hybrid signals
- Uses behavioral analytics
- Finds identity-based attacks
- Surfaces risk in the identity usage

- **Detects**

- Credential theft
- Golden ticket / silver ticket attacks
- DCSync and DCShadow
- Reconnaissance
- Lateral movement

- **Signals sent to Sentinel / XDR**

- Endpoint activity
- Email signals
- Unusual cloud app behavior

- **Signals for Microsoft Identity Threat Detection and Response (ITDR)**

- On-prem AD activity
- Lateral movement
- Kerberos abuse
- Domain dominance attempts

References

Conditional Access for workloads

<https://learn.microsoft.com/en-us/azure/active-directory/conditional-access/workload-identity>

Require MFA for all users

<https://learn.microsoft.com/en-us/azure/active-directory/conditional-access/howto-conditional-access-policy-all-users-mfa>

Defender for Identity

<https://learn.microsoft.com/en-us/defender-for-identity/>



Implement access management for Azure resources



Objectives

- 1 Assign Azure roles
- 2 Configure a custom Azure role
- 3 Create and configure managed identities
- 4 Access Azure resources with managed identities
- 5 Analyze Azure role permissions
- 6 Configure Azure Key Vault policies and access objects

Assign Azure roles



Identities and roles

Azure role-based access control (Azure RBAC) is the authorization system to manage access to Azure resources. Assign roles to users, groups, service principals, or managed identities at a particular scope.

Who needs access	What role to assign
Identities • User • Group • Service Principal • Managed Identity	Built-in Azure roles • Owner – Full access to all resources. • Contributor – Can create and manage all types of Azure resources, but can't grant access. • Reader – Can view the available Azure resources. • User Access Administrator – Assign access to Azure resources. • Other task specific roles, like Virtual Machine Contributor, can be assigned.

What scope to assign?

Management Group – Subscription – Resource Group - Resource

Assign a role in the Azure portal

The screenshot shows the 'Access control (IAM)' page in the Azure portal for a resource group named 'rgBuild'. The left-hand navigation pane is visible, with 'Access control (IAM)' highlighted by a red rectangle. The main content area displays a warning banner about elevated access, followed by tabs for 'Check access', 'Role assignments', 'Roles', 'Deny assignments', and 'Classic administrators'. The 'Check access' tab is active, showing a 'Check access' button and a section for 'Current User Assignments'. This section includes a summary table with columns for Active, Eligible, and Deny assignments, and a table below showing the current assignment for the 'User Access Administrator' role.

rgBuild | Access control (IAM) ☆ ...
Resource group

Search × << + Add ▾ ↓ Download role assignments ≡ Edit columns ↻ Refresh | 🗑 Delete | 🗨 Feedback

Overview
Activity log
Access control (IAM)
Tags
Resource visualizer
Events
> Settings
> Cost Management
> Monitoring
> Automation
> Help

⚠ **Action required:** 1 user has elevated access in your tenant. You should take immediate action and remove all role assignments

Check access Role assignments Roles Deny assignments Classic administrators

📘 Looking for the previous check access view? [Click here.](#)

Check access
Review the level of access a user, group, service principal, or managed identity has to this resource. [Learn more](#) ⓘ

Check access

Current User Assignments

Active ⓘ	Eligible ⓘ	Deny ⓘ
1	0	0

🔍 Search by role name or membership

Role Name ↑↓	Scope ↑↓	Membership ↑↓
▼ Active permanent assignments (1)		
User Access Administrator	Root (Inherited)	
Active time-bound assignments (0)		
Eligible permanent assignments (0)		
Eligible time-bound assignments (0)		

Assign a role using script

PowerShell

```
New-AzRoleAssignment -ObjectId <objectId> `
-RoleDefinitionName <roleName> `
-Scope
/subscriptions/<subscriptionId>/resourcegroups/<resourceGroupName>/providers/<providerName>/<resourceType>/<resourceSubType>/<resourceName>
```

CLI scripting

```
az role assignment create --assignee "{assignee}" \
--role "{roleNameOrId}" \
--resource-group "{resourceGroupName}"
```


Configure a custom Azure role

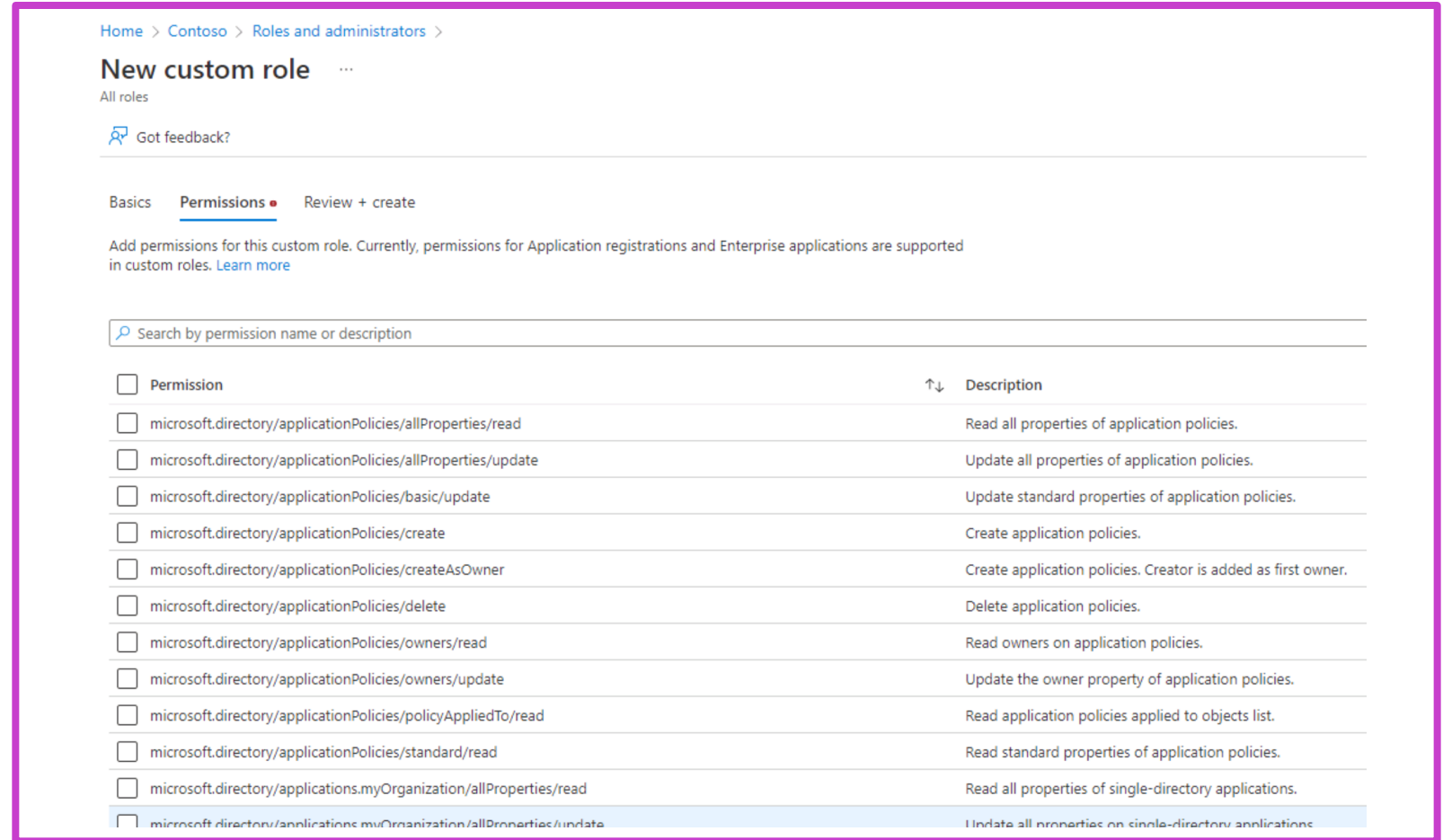


Create a custom role

The principle of least privilege lets you pick just the capabilities you need.

To create the custom role:

1. Open Microsoft Entra admin center then open Identity.
2. Select **Roles and administration**.
3. Select **+ New custom role**.
4. Then name and assign the capabilities needed.



Create a custom role using JSON

The asterisk (*) is used as a wildcard. If you need to assign all of the read permissions from the Billing resource, use this command:

Microsoft/Billing//read.*

The wildcard can exist at any level.

```
{
  "properties": {
    "roleName": "Billing Reader Plus",
    "description": "Read billing data and download invoices",
    "assignableScopes": [
      "/subscriptions/your-subscription-number"
    ],
    "permissions": [
      {
        "actions": [
          "Microsoft.Authorization/*/read",
          "Microsoft.Billing/*/read",
          "Microsoft.Commerce/*/read",
          "Microsoft.Consumption/*/read",
          "Microsoft.Management/managementGroups/read",
          "Microsoft.CostManagement/*/read",
          "Microsoft.Support/*"
        ],
        "notActions": [],
        "dataActions": [],
        "notDataActions": []
      }
    ]
  }
}
```

Create and configure managed identities



Types of Managed Identities

Identity type	Description and usage
System-assigned	Some Azure services allow you to enable a managed identity directly on a service instance. When you enable a system-assigned managed identity, an identity is created in Microsoft Entra ID. The identity is tied to the lifecycle of that service instance. When the resource is deleted, Azure automatically deletes the identity for you. By design, only that Azure resource can use this identity to request tokens from Microsoft Entra ID.
User-assigned	You may also create a managed identity as a standalone Azure resource. You can create a user-assigned managed identity and assign it to one or more instances of an Azure service. For user-assigned managed identities, the identity is managed separately from the resources that use it.

Benefits of using managed identities

- You don't need to manage credentials. Credentials aren't even accessible to you.
- You can use managed identities to authenticate to any resource that supports Microsoft Entra authentication, including your own applications. Managed identities can be used without any extra cost.

Use a managed identity in the Azure portal

The screenshot displays the Azure portal interface. On the left, the 'TestManagedIdentities | Managed identities' page is visible, with the 'Managed identities' option highlighted in the left-hand navigation pane. The main content area shows the 'User assigned' tab selected, with a red box around the 'Add' button. Below the 'Add' button, a table with the header 'Name' shows 'No results'. On the right, the 'Add user assigned managed identity' dialog is open. It features a 'Select a subscription' dropdown menu set to 'Visual Studio Enterprise Subscription'. Below this, a search bar is labeled 'User assigned managed identities' with a filter icon and the text 'Filter by identity name and/or resource group name'. The dialog also displays the message 'No user assigned managed identities found based on the search term.' and 'Selected identities: No user assigned managed identities selected. Select one or more user assigned managed identities you want to assign to this resource.'

Assign a managed identity in script

CLI

```
az webapp identity assign --resource-group <group-name> --name <app-name> --identities <identity-name>
```

PowerShell

```
Update-AzFunctionApp -Name <app-name> -ResourceGroupName <group-name> -IdentityType  
UserAssigned -IdentityId $userAssignedIdentity.Id
```

Within a template

```
"identity": {  
  "type": "UserAssigned",  
  "userAssignedIdentities": {  
    "<RESOURCEID>": {}  
  }  
}
```

Access Azure resources with managed identities



Managed identities and Azure resources

Scenario:

- Application needs to access outside resources like a database or storage account
- How can a developer do this securely?
- You don't want to embed an account/password into the application.

Use a managed identity:

- Assign a managed identity to an application or virtual machine.
- Open the applications properties.
- Launch the Access Control (IAM).
- Add a role assignment to grant the needed access and resource.

Assigning a resource and managed identity

Home > vmBuild | Access control (IAM) >

Add role assignment ...

Role **Members** Conditions Review + assign

Selected role Avere Operator

Assign access to ☐ User, group, or service principal ☒ **Managed identity**

Members [+ Select members](#)

Name	Object ID	Type
No members selected		

Description Optional

Select managed identities

⚠ Some results might be hidden due to your ABAC condition.

Subscription *
Visual Studio Enterprise Subscription

Managed identity
Select

Search by resource type

System-assigned managed identity

- All system-assigned managed identities (1)
- Virtual machine (1)

Select Close

Feedback

Configure Azure Key Vault RBAC policy



Key Vault Access policy

- You can grant access to Azure Key Vault using either role-based access control (RBAC) or Key Vault access policies.
- Either method works to protect your secrets, certificates, and keys.
- Access policies give you a little more granular control, but can be harder to manage.
- Choose the best option based on your security posture needs.

[Home](#) > [Key vaults](#) > [kv1234sc300lab](#) >

Add access policy ...

Add access policy

Configure from template (optional)

Key permissions

Secret permissions

Certificate permissions

Select principal *

Authorized application ⓘ

Add

0 selected

☐ Select all

Key Management Operations

☐ Get

☐ List

☐ Update

☐ Create

☐ Import

☐ Delete

☐ Recover

☐ Backup

☐ Restore

Cryptographic Operations

☐ Decrypt

☐ Encrypt

☒ Unwrap Key

☐ Wrap Key

☐ Verify

☐ Sign

Privileged Key Operations

☐ Purge

☐ Release

Rotation Policy Operations

Key Vault and RBAC policies

Assign access with RBAC to Key Vault

kvBuild04242025 | Access control (IAM)

☆ ...

Key vault

Search

◇ <<

+ Add ▾

↓ Download role assignments

≡ Edit columns

🔄 Refresh

| 🗑 Delete

| 👤 Feedback

Overview

Activity log

Access control (IAM)

Tags

Diagnose and solve problems

Access policies

Resource visualizer

Events

> Objects

> Settings

> Monitoring

> Automation

> Help

⚠ Action required: 1 user has elevated access in your tenant. You should take immediate action and remove all role assignments with elevated access. [View role assignment](#)

Check access

Role assignments

Roles

Deny assignments

Classic administrators

My access

View my level of access to this resource.

View my access

Check access

Review the level of access a user, group, service principal, or managed identity has to this resource. [Learn more](#)

Check access

Grant access to this resource

Grant access to resources by assigning a role.
[Learn more](#)

Add role assignment

View access to this resource

View the role assignments that grant access to this and other resources.
[Learn more](#)

View

View deny assignments

View the role assignments that have been denied access to specific actions at this scope.
[Learn more](#)

View

Built-in Azure Key Vault roles

Built-in role	Description
Key Vault Administrator	Perform all data plane operations on a key vault and all objects in it, including certificates, keys, and secrets. Can't manage key vault resources or manage role assignments.
Key Vault Certificates Officer	Perform any action on the certificates of a key vault, except manage permissions.
Key Vault Crypto Officer	Perform any action on the keys of a key vault, except manage permissions.
Key Vault Crypto Service Encryption User	Read metadata of keys and perform wrap/unwrap operations.
Key Vault Crypto User	Perform cryptographic operations using keys.
Key Vault Reader	Read metadata of key vaults and its certificates, keys, and secrets. Can't read sensitive values such as secret contents or key material.
Key Vault Secrets Officer	Perform any action on the secrets of a key vault, except manage permissions.
Key Vault Secrets User	Read secret contents.

Retrieve objects from Azure Key Vault



Retrieve a secret from Key Vault in the Azure portal

- Azure Key Vault is a secure tool for storing secrets, keys, and certificates.
- Once stored, these items can be used by users and applications to perform actions and operations in a secure method.

Retrieval methods:

- Key Vault UI
- Scripting/code

Home > Key vaults > kv1234sc300lab > mySC300keyvaultSecret >

 **ba6102eeaf724b23bdea13e835260de6**
Secret Version

 Save  Discard changes

Properties

Created 6/19/2022, 3:37:12 PM

Updated 6/19/2022, 3:37:12 PM

Secret Identifier

Settings

Set activation date ⓘ ☐

Set expiration date ⓘ ☐

Enabled Yes No

Tags 0 tags

Secret

Content type (optional)

Hide Secret Value

Secret value

This is my secret

Retrieve a secret from Key Vault in code/script

Azure CLI

```
az keyvault secret show --name "mySC300keyvaultSecret" --vault-name "<your-unique-keyvault-name>" --query "value"
```

PowerShell

```
$secret = Get-AzKeyVaultSecret -VaultName "<your-unique-keyvault-name>" -Name "mySC300keyvaultSecret" -AsPlainText
```

Application code

If you're building an application that needs access to your key vault secrets, certificates, and keys that can be done. You can access the key vault using .NET, Node.js, Python, and other languages.

References

- [Assign Azure roles using the Azure portal – Azure RBAC](#)
- [Create or update Azure custom roles using the Azure portal – Azure RBAC](#)
- [Configure managed identities using the Azure portal – Microsoft Entra ID](#)
- [Assign a managed identity access to a resource using the Azure portal – Microsoft Entra ID](#)
- [Understand Azure role definitions – Azure RBAC](#)
- [Grant permission to applications to access an Azure key vault using Azure RBAC](#)
- [Create and access a secret in Azure Key Vault](#)



Deploy and configure Global Secure Access with Microsoft Entra



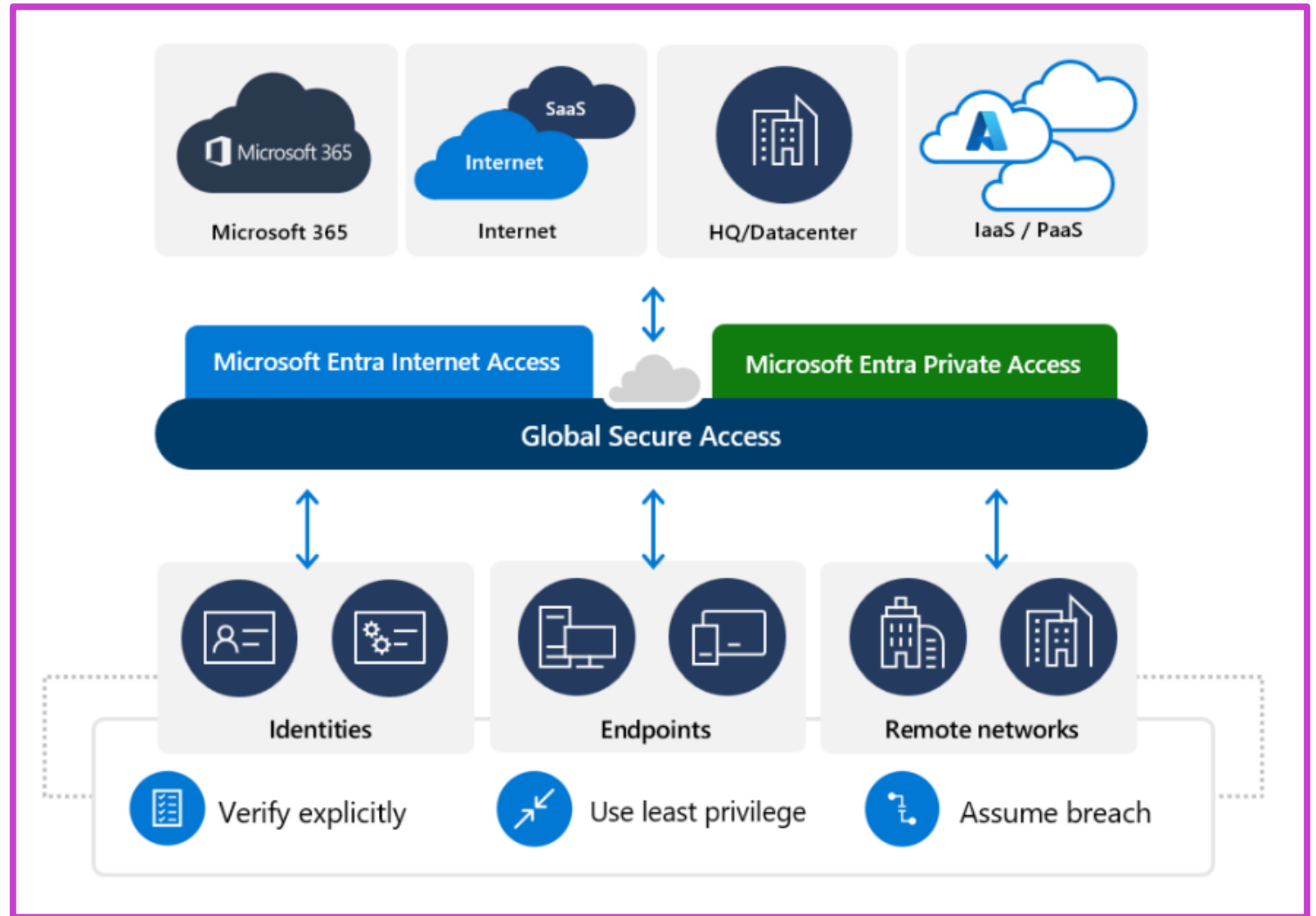
Objectives

- 1 Define Global Secure Access and its components
- 2 Explore deployment and configuration of Microsoft Entra Internet Access
- 3 Explore deployment and configuration of Microsoft Entra Private Access
- 4 Use the Global Secure Access Dashboard to monitor your systems
- 5 Configure Remote Networks
- 6 Create Conditional Access based on Global Secure Access

What is Global Secure Access?

Microsoft Security Service Edge (SSE)

- Microsoft Entra Internet Access
 - Secure access to Microsoft services, SaaS apps, and public internet apps
- Microsoft Entra Private Access
 - Secure access to private corporate resources.



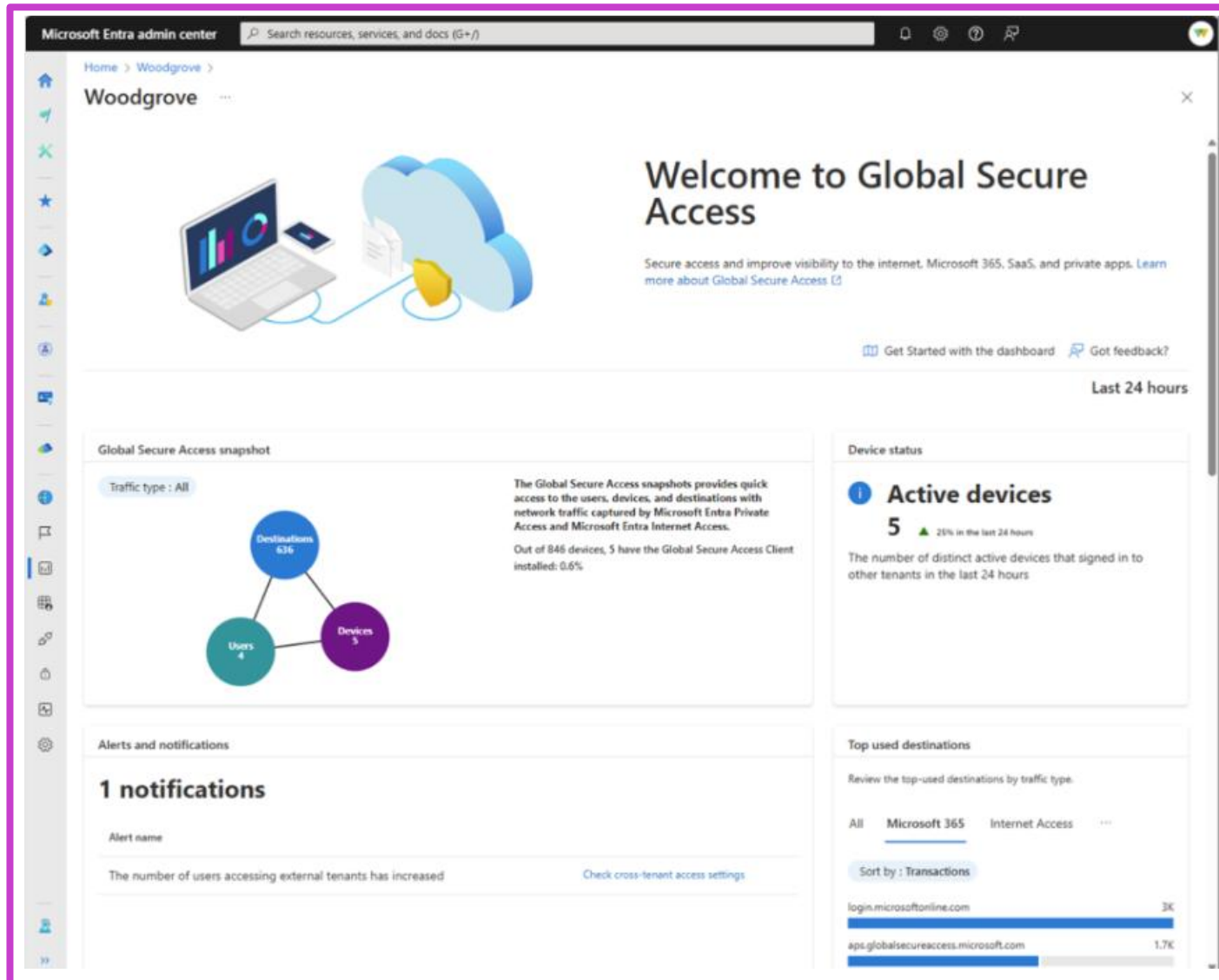
Deploy and configure Microsoft Entra Internet Access

Steps	Description
1. Enable the Microsoft traffic forwarding profile.	With the Microsoft profile enabled, Microsoft Entra Internet Access acquires the traffic going to Microsoft services, like Exchange Online and SharePoint Online.
2. Install the Global Secure Access Client on end-user devices.	Download and install the client app to capture and control access from the client.
3. Enable tenant restrictions.	Configure which tenants / organizations are allowed to blocked.
4. Enable enhanced Global Secure Access signaling and Conditional Access.	Use Conditional Access and Global Secure Access to prevent attacks.

Deploy and configure Microsoft Entra Private Access

Steps	Description
1. Configure a Microsoft Entra private network connector and connector group.	Create connection between an on-premises server and Global Secure Access.
2. Configure Quick Access to your private resources.	Define specific fully qualified domain names (FQDNs) or IP addresses of private resources to include in Microsoft Entra Private Access.
3. Enable the Private Access traffic forwarding profile.	Turn on Private Access and link from on-premises router to remote networks.
4. Install and configure the Global Secure Access Client on end-user devices.	Deploy the client software onto devices, so they can access the traffic flow.

Global Secure Access Dashboard



Reporting widgets and deeper details:

- Global Secure Access snapshot
- Alerts and notifications
- Usage profiling
- Top used destinations
- Cross-tenant access
- Web category filtering
- Device status

Conditional Access updates with Global Secure Access

New Conditional Access check	What it does
Compliant network check	Ensures users connect from a verified network connectivity model for their specific tenant and are compliant with security policies enforced by administrators.
Private Access apps	Microsoft Entra Private Access apps is a powerful way to enforce security policies for your internal, private resources.
Source IP restoration	Source IP restoration in Global Secure Access allows backward compatibility for Microsoft Entra customers to continue using original user Source IP.

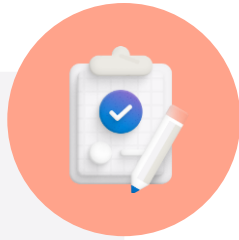
- **Always remember to protect your break-glass accounts.**
- **You can combine new and existing conditions for more security.**

References

- [Global Secure Access documentation - Global Secure Access](#)
- [Learn about Microsoft Entra Private Access - Global Secure Access](#)
- [Learn about Microsoft Entra Internet Access - Global Secure Access](#)
- [Learn about Universal Conditional Access through Global Secure Access - Global Secure Access](#)



Summary



Plan and implement MFA

- Plan your MFA deployment
- Configure and manage MFA settings
- Manage MFA for users
- Core piece of Zero Trust

Conditional Access

- Conditional Access policies
- Testing and troubleshooting CA
- Implement application controls
- Session management

Manage user authentication

- Configure authentication methods (passwords to passwordless)
- Windows Hello for Business
- Use Password Protection and Smart Lockout
- Implement tenant restrictions

Identity Protection

- Implement user risk policy
- Configure sign-in risk policies
- Manage MFA registration policy
- Remediate elevated risky users

Access Azure resources

- Built-in and custom roles
- Managed identities
- Key Vault identity level access

Labs

6 Google fcd
7 AD Sync



Lab	Brief description	Length
8. Enable MFA	Configure multifactor authentication policies, set up Conditional Access rules, and configure Microsoft Entra MFA for passwords.	10 minutes
9. Configure and deploy <u>SSPR</u>	Enable self-service password reset, register a cell phone number, and test self-service password reset.	15 minutes
10. <u>Microsoft Entra ID</u> Authentication for Windows and Linux VMs	Configure Microsoft Entra ID authentication on a virtual machine running Windows or Linux.	15 minutes
11. Assign Azure resources	Use <u>PIM</u> to assign Azure resource roles	10 minutes
12. Manage Microsoft Entra smart lockout values.	Customize the Microsoft Entra smart lockout values.	5 minutes
13. Implement Conditional Access	Create and test a Conditional Access policy. I	10 minutes
14. Enable sign-in risk policy	Enable a user risk policy and a sign-in risk policy.	10 minutes
15. Configure MFA registration policy	Configure a multifactor authentication registration policy.	5 minutes
16. Key Vault and managed identities	Configure an Azure Key Vault for access from a managed identity	10 minutes

Learning path recap

In this learning path, we learned how to:

Configure and manage authentication including MFA.

Implement Zero Trust using Conditional Access and other tools.

Create and manage identities for use with resources and applications.



